CURSO *ONLINE* DE CIBERSEGURIDAD

Unidad 5. Protección de datos y cumplimiento de RGPD



GOBIERNO DE ESPAÑA
VICEPRESIDENCIA PRIMERA DEL GOBIERNO
MINISTERIO DE ASUNTOS ECONÓMICOS Y TRANSFORMACIÓN DIGITAL
SECRETARÍA DE ESTADO DE DIGITALIZACIÓN E INTELIGENCIA ARTIFICIAL
incibe_
INSTITUTO NACIONAL DE CIBERSEGURIDAD
017

Contenidos

1	INTRODUCCIÓN	6
2	LOPD Y RGPD	35
3	RGPD Y ACTUALIZACIÓN DE LOPDGDD	48
4	DERECHOS ARCO-POL	80
5	FIGURAS RELEVANTES	104

Contenidos

6	MEDIDAS DE CUMPLIMIENTO	119
7	INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO	135
8	GARANTÍAS DE LOS DERECHOS DIGITALES	153
9	ESTÁNDAR NORMATIVO ISO 27701	159

OBJETIVOS

Los principales objetivos de esta unidad son:

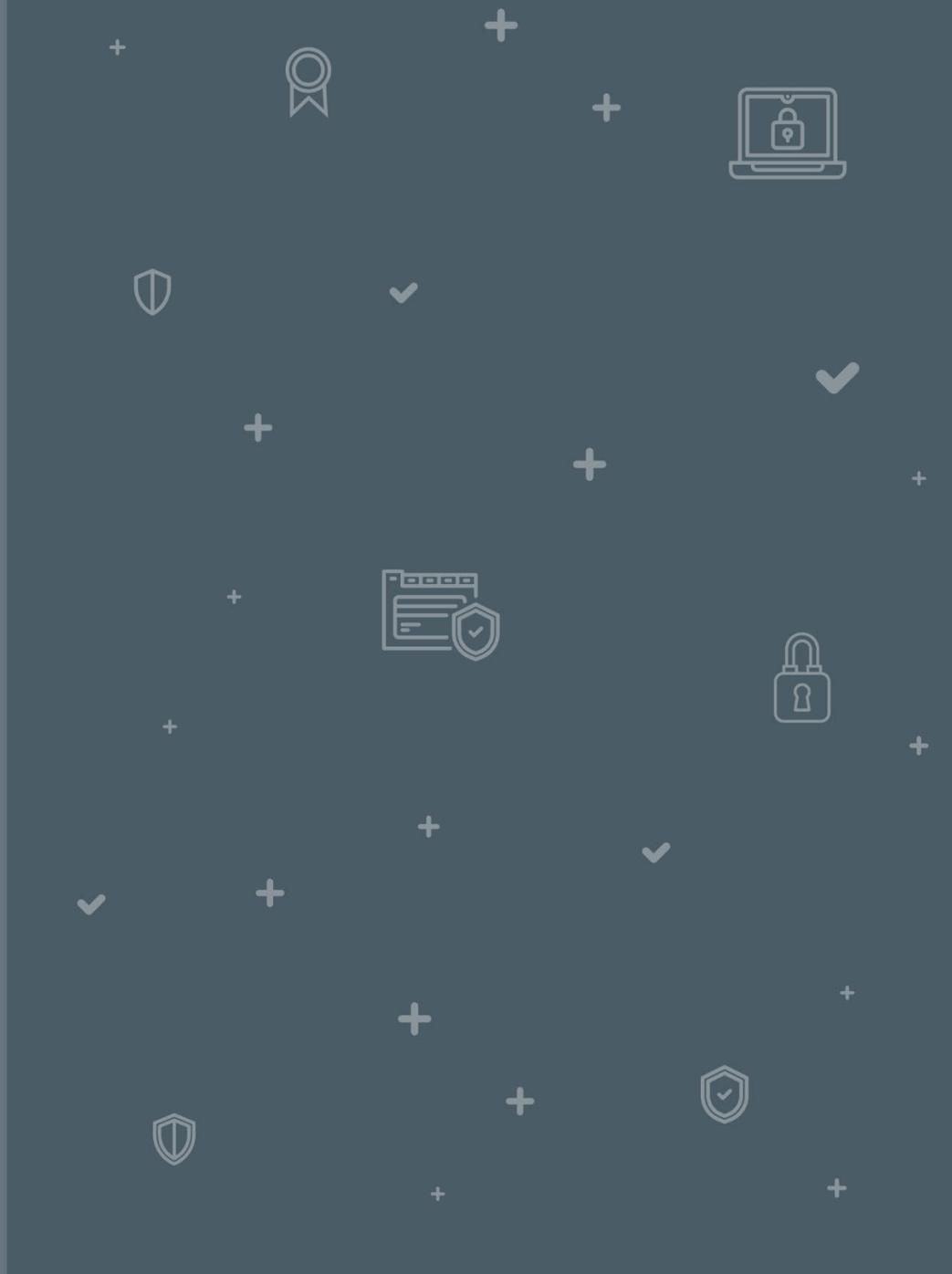
- Entender el marco contextual actual y conocer la relación entre los conceptos de seguridad y privacidad de los datos, además de las diferencias que existen entre ellos. Comprender el concepto de *compliance* y conocer los tipos que podemos encontrar y cuál son los objetivos que corresponden en cada caso.
- Analizar el concepto de datos personales, cuál es su clasificación y ciclo de vida para, posteriormente, describir en qué consiste el tratamiento de datos.
- Entender el contexto a través del cual evolucionó la antigua Ley Orgánica de Protección de Datos (LOPD) al Reglamento General de Protección de Datos (RGPD) y a la Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD), que deroga la LOPD.

OBJETIVOS

Los principales objetivos de esta unidad son:

- Analizar la legislación actual relativa a protección de datos, regulada en el Reglamento General de Protección de Datos y en la LOPDGDD, así como describir cuáles son principios que recoge el RGPD, los Derechos ARCO-POL, qué figuras relevantes existen en el tratamiento de los datos, cuáles son sus obligaciones y medidas de cumplimiento del RGPD establecidas; y, por último, comprender cómo funciona el procedimiento sancionador en caso de infracción y comprender diversos conceptos en materia de derechos digitales.

INTRODUCCIÓN



1 INTRODUCCIÓN

Marco contextual

Vivimos en un mundo hiperconectado y cada vez más globalizado donde el uso de Internet, las redes sociales y la migración o transferencia de datos están a la orden del día. La infiltración, su uso indebido y los ciberataques han aumentado la preocupación sobre la protección de datos, convirtiéndose así en un aspecto esencial y prioritario, tanto para las organizaciones como para los usuarios.

La protección de datos personales forma parte del derecho a la intimidad que tienen todas las personas, ya que se trata de un derecho fundamental recogido en el artículo 18 de la Constitución Española, en la Carta de los Derechos Fundamentales de la Unión Europea y en el Tratado de Funcionamiento de la Unión Europea. [1]

1 INTRODUCCIÓN

Marco contextual

Tal y como cita el artículo 18:

«1. Se garantiza el derecho al honor, a la intimidad personal y familiar y a la propia imagen. 2. El domicilio es inviolable. Ninguna entrada o registro podrá hacerse en él sin consentimiento del titular o resolución judicial, salvo en caso de flagrante delito. 3. Se garantiza el secreto de las comunicaciones y, en especial, de las postales, telegráficas y telefónicas, salvo resolución judicial. ***4. La ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos****»*.



1 INTRODUCCIÓN

Marco contextual

Después de haber comprendido que el derecho a la protección de datos supone un derecho fundamental, veamos qué quiere decir este concepto. Según la RAE, los derechos fundamentales son «*derechos declarados por la Constitución, que gozan del máximo nivel de protección*», es decir, se trata de derechos **inalienables**, esto es, no se puede comerciar con ellos, **inviolables**, ya que no se puede atentar contra ellos, lesionarlos o destruirlos; e **irrenunciables**, por lo que no se puede renunciar a ellos, pues son inherentes a las personas.

Por tanto, la protección de datos está basada en el control sobre el uso que se hace de los datos personales, permitiendo evitar así que se pueda llegar a disponer de información sobre las personas que pueda afectar a su intimidad y demás derechos fundamentales y libertades públicas. La protección de datos engloba las prácticas y principios fundamentales que se deben llevar a cabo para salvaguardar la información personal de las personas, independientemente del soporte en el que se encuentre, digital o físico, contra su posible corrupción o pérdida. Así, una persona puede ejercer su derecho a la protección de datos cuando considere que se está haciendo un uso indebido de sus datos.

1 INTRODUCCIÓN

Marco contextual

¿Sabías qué?

A principios de 2014, unos ciberdelincuentes robaron más de 3.000 millones de datos de usuarios. [2]



1 INTRODUCCIÓN

Marco contextual

La protección de datos ha cobrado gran importancia en los últimos años, creándose así el Reglamento General de Protección de Datos (RGPD) de la Unión Europea (Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016). Este reglamento entró en vigor en 2016 y tiene por objeto reforzar y unificar la protección de los datos de los individuos europeos, así como la libre circulación de datos personales en el territorio de la Unión Europea.

Además, en España, también destaca la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos y Garantías de los Derechos Digitales (LOPDGDD) que entró en vigor en 2018, sustituyendo así a la anterior Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal (LOPD). Esta ley tiene como fin adaptar el Derecho español al RGPD y completar algunos aspectos que el RGPD permite regular a los países de la Unión Europea.

1 INTRODUCCIÓN

Marco contextual

Aunque podemos encontrar varias normativas sobre esta materia, en esta unidad nos centraremos en el RGPD, la LOPD y la nueva LOPDGDD. Haz clic en las imágenes para obtener más información.



RGPD



LOPD
(Derogada)



LOPDGDD

1 INTRODUCCIÓN

La seguridad y la privacidad de los datos: conceptos

Cuando hablamos de protección de datos, debemos comprender primero algunos conceptos clave:

- **La seguridad de los datos:** hace referencia a las medidas de protección de la información. La seguridad de los datos tiene el objetivo de evitar accesos no autorizados a los ordenadores, las bases de datos, los sitios web, etc., es decir, se centra en los principios de confidencialidad, integridad y disponibilidad de la información. Consiste en proteger los datos contra amenazas internas, externas, maliciosas y accidentales. Para lograr una adecuada seguridad de los datos se utilizan herramientas y soluciones, como cortafuegos o *firewalls*, la autenticación de usuarios y buenas prácticas adaptadas a cada organización, entre otras.
- **La privacidad de los datos:** también conocida como privacidad de la información, esta se basa en asegurar que los datos, independientemente de que se encuentren procesados, almacenados o transmitidos, sean consumidos o utilizados de acuerdo a regulaciones y normas; además de que solo puedan ser manipulados con el consentimiento del propietario de los mismos.

1 INTRODUCCIÓN

La seguridad y la privacidad de los datos: ¿cuáles son las diferencias entre ellas?

Aunque ambos conceptos conforman los pilares de la protección de datos, existen algunas diferencias entre ellos:

- Mientras que la **privacidad** se basa en el uso adecuado y el control de la información o los datos personales tratando de evitar que queden expuestos a cualquier persona ajena, la **seguridad** se encarga de la protección de dicha información, tratando de evitar así que un intruso pueda acceder a ella, sin que eso implique que la información sea expuesta.
- En función de la actuación de terceros respecto a los datos personales, la **privacidad** se refiere a cómo ese tercero gestionará esos datos personales y cómo podría o no comprometer la identidad del usuario; mientras que la **seguridad** hace referencia a las herramientas que el tercero va a utilizar para evitar que un intruso acceda a la base de datos o al lugar donde almacena los datos personales de los usuarios y así recopilarlos.

Por lo tanto, mientras que la seguridad pretende proteger los datos contra accesos no autorizados, la privacidad se relaciona con el acceso autorizado, esto es, quién tiene derecho a acceder a la información y quién define este derecho.

1 INTRODUCCIÓN

La seguridad y la privacidad de los datos: ¿cuáles son las diferencias entre ellas?

Imaginemos que un usuario descarga una aplicación en su teléfono móvil. Antes de hacerlo ha tenido que aceptar un acuerdo de privacidad que le ha permitido descargar dicha aplicación e instalarla en su móvil. Después, la aplicación puede tratar de acceder a ciertos datos personales, como los contactos, las imágenes, documentos, etc. El usuario puede aceptarlo o rechazarlo aunque, en ocasiones, es necesario otorgar esos permisos para utilizar la aplicación. Una vez ha otorgado los permisos, serán los desarrolladores de la aplicación quienes deban asegurar los datos del usuario y proteger su privacidad de accesos no autorizados.



1 INTRODUCCIÓN

La seguridad y la privacidad de los datos: ¿cuáles son las diferencias entre ellas?

No se puede garantizar la privacidad a menos que los datos estén seguros, ya que si los datos no están protegidos por la tecnología de forma adecuada, un usuario no autorizado podría robarlos y, por tanto, la privacidad quedaría vulnerada. Esta relación a la inversa no tiene por qué darse en todos los casos, pues los datos sí pueden encontrarse debidamente protegidos aunque la privacidad no sea completa. Esto es debido a que la tecnología encargada de proteger los datos por sí sola no puede garantizar la privacidad de los mismos, ya que la privacidad depende de las personas autorizadas que puedan acceder a ellos y, por tanto, se trata de una responsabilidad que recae sobre estas personas y no sobre la tecnología utilizada para proteger los datos.



1 INTRODUCCIÓN

Datos personales

Los **datos personales** conforman el núcleo sobre el que se desarrolla el Reglamento General de Protección de Datos (RGPD).

Según el RGPD, en su artículo 4, los datos personales se definen como «*toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como, por ejemplo, un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona*».

Por lo tanto, podemos decir que los datos personales son toda aquella información que nos permita, de forma directa o indirecta, identificar a una persona concreta, como, por ejemplo, su nombre completo, su DNI, sus datos de localización, etc.

1 INTRODUCCIÓN

Tipos de datos personales

Según el tipo de datos personales, diferenciamos entre:

- **Datos de carácter personal**: en este tipo de datos podemos encontrar una subcategoría que clasifique los datos según sean generales / ordinarios o sensibles.
  - Los **datos personales ordinarios** comprenden aquella información personal como el nombre completo, la dirección, las circunstancias relacionadas con el trabajo, las circunstancias familiares, calificaciones, fecha de nacimiento, la dirección IP u otra información similar que no sea sensible.

1 INTRODUCCIÓN

Tipos de datos personales

- Los datos **especialmente protegidos o sensibles o las categorías especiales de datos** están conformados por datos que deben tratarse con mayor precaución, ya que su recopilación y uso puede interferir con los derechos fundamentales o pueden llegar a exponer a las personas a la discriminación. Encontramos diferentes subcategorías:
  - **Origen étnico o cultural**: hace referencia a la raza o la etnia de las personas, siendo la etnia una «*comunidad humana definida por afinidades raciales, lingüísticas, culturales, etc.*», según la RAE.
  - **Opiniones políticas, religiosas y filosóficas**.
  - **Orientación sexual y de género**.
  - **Afiliación sindical:** hace referencia al hecho de que una persona esté afiliada a un sindicato.

1 INTRODUCCIÓN

Tipos de datos personales

- **Datos genéticos**: todos aquellos datos referentes a las características genéticas heredadas o adquiridas de una persona física que facilitan información única sobre la fisiología o la salud de dicha persona, como el ADN o el ARN. Sin embargo, hay ocasiones en las que los datos genéticos no conforman un dato personal identificable como es el caso de anonimizar esos datos o simplemente mostrar resultados parciales y, por tanto, dejan de ser datos sensibles.

- **Datos biométricos**: son aquellos datos personales que recogen las características físicas, fisiológicas o de comportamiento de una persona física que facilitan la identificación única de dicha persona. Por ejemplo, las huellas dactilares, el examen de retina, el reconocimiento facial o por voz, o de la mirada, etc.

¿Sabías qué?

El análisis de pulsaciones de teclas se considera un dato biométrico, donde se analiza en tiempo real las pulsaciones de teclado o gestos táctiles del usuario y se contrastan con patrones registrados previamente.

1 INTRODUCCIÓN

Tipos de datos personales

- **Datos relativos a la salud:** se trata de aquellos datos que hacen referencia a la salud física o mental de una persona física, ya sea pasada, actual o futura; incluyendo en este tipo la prestación de servicios de atención médica, pruebas, tratamientos, etc. Aquí encontramos datos sobre lesiones, enfermedades, discapacidades, resultados de pruebas, detalles de citas y facturas que revelen información de la salud de la persona, etc.

- **Datos de naturaleza penal:** esta categoría hace referencia a los datos personales sobre las denuncias, los procedimientos o las condenas penales. No se trata de datos de categoría especial, sin embargo, se debe tener autoridad legal u oficial o una base legal para poder procesar o tratar este tipo de datos.



1 INTRODUCCIÓN

Tipos de datos personales

No todos los datos de una persona física se consideran datos personales, ya que aquellos datos que se encuentren anonimizados no serán datos personales siempre que no se pueda reidentificar a la persona física a la que corresponden, como, por ejemplo, los datos anonimizados utilizados para estadísticas.

Los datos de empresarios individuales (comúnmente conocidos como autónomos) sí se consideran datos personales. El ejemplo más claro es el NIF o Número de Identificación Fiscal, que permite identificar a las personas físicas y jurídicas a efectos fiscales. En el caso de personas autónomas, el NIF coincidirá con su DNI o Documento Nacional de Identidad; o su NIE o Número de Identidad de Extranjero, por lo que el tratamiento de estos datos solo podrá realizarse cuando exista un interés legítimo.



1 INTRODUCCIÓN

Tipos de datos personales

Sin embargo, respecto a las personas jurídicas, ningún dato de las mismas se considera dato personal, ni su nombre completo, ni sus datos de contacto, etc.

Por lo tanto, independientemente del tipo de datos personales que se traten, siempre debe cumplirse el RGPD y la LOPDGDD para no vulnerar ningún derecho ni comprometer los datos.



1 INTRODUCCIÓN

Tratamiento de datos

Sobre esos datos personales que acabamos de ver, podemos realizar una serie de operaciones que el legislador denomina «**tratamiento de datos**».

El artículo 4 del RGPD define el tratamiento como «*cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción*».

Un aspecto clave en el tratamiento de datos personales es la **finalidad del tratamiento**, que hace referencia a los motivos, usos y objetivos que se aplicarán sobre los datos recabados. Esta finalidad debe tener una base legal, es decir, debe estar recogida en el RGPD o la LOPDGDD que legitime dicho tratamiento.

1 INTRODUCCIÓN

Tratamiento de datos

Por lo tanto, el tratamiento de datos consiste en realizar una serie de operaciones con ellos, tales como su recogida, modificación, difusión, etc., con un fin concreto. Por lo tanto, la finalidad del uso de los datos delimita su propio tratamiento. Por ejemplo, sería el caso de la recogida de los datos biométricos que lleve a cabo una organización para habilitar el acceso a las oficinas utilizando las huellas dactilares de los empleados. En este caso, el tipo de tratamiento sería la recogida de datos y su comprobación, el tipo de datos personales sería datos biométricos y la finalidad del tratamiento tendría como objetivo conceder al empleado el acceso a las instalaciones de la empresa.



Saber más: si quieres saber más acerca del tratamiento de datos, puedes consultar la Guía de la Agencia Española de Protección de Datos. [3]

1 INTRODUCCIÓN

Ciclo de vida de los datos

Durante el procesamiento de los datos, se llevan a cabo una serie de fases desde el momento de la recogida de los mismos hasta su eliminación. Este proceso se conoce como ciclo de vida de los datos y, por lo general, existen cinco etapas o categorías: la recogida o generación de los datos, el registro o almacenamiento, el uso y tratamiento de datos, la comunicación o cesión de los mismos y su finalización o destrucción.

Cabe destacar que, aunque el término «tratamiento» aquí se emplea en la tercera etapa, cuando se habla del tratamiento de los datos, o el riesgo del tratamiento de los datos, se hace referencia a todo el ciclo de vida de los datos.



Ciclo de vida de los datos: recogida o generación

1

Recogida / Generación

- **Recogida o generación**: esta categoría se centra en la obtención de los datos personales y se puede realizar a través de diferentes métodos, como encuestas, formularios, fuentes de información pública o que los suministren los propios interesados o terceros. En esta fase solo se deben recoger los datos que sean necesarios para lograr la finalidad del tratamiento.

¿Sabías qué?

La AEPD sancionó con un millón de euros a una organización por recopilar datos incumpliendo la normativa. [4]

Ciclo de vida de los datos: recogida o generación

2

Registro / Almacenamiento

- **Registro o almacenamiento**: los datos se deben clasificar según su categoría, es decir, si son datos ordinarios, especialmente protegidos, relativos a condenas, etc., y, en función de ello, se determinará el tipo de almacenamiento para cada dato. Por ejemplo, si se trata de datos sensibles o especialmente protegidos, deberán establecer medidas de protección más estrictas o restringir su acceso a determinadas personas. También se debe tener en cuenta que si se recogen datos que finalmente no son necesarios para lograr la finalidad deseada, esos datos deberán destruirse.

Ciclo de vida de los datos: recogida o generación

3

Uso y tratamiento

- **Uso y tratamiento**: a raíz del artículo 5 del RGPD se establece que los datos deberán «*ser tratados de manera lícita, leal y transparente en relación con el interesado*», por lo que, en primer lugar, se examinará de manera transparente si existe una base legal para realizar el tratamiento de los datos donde los propietarios sepan qué acciones se van a llevar a cabo con sus datos y qué finalidades tienen.

Ciclo de vida de los datos: recogida o generación

4

Comunicación / Cesión

- **Comunicación o cesión a terceros**: esta fase hace referencia a la necesidad o no de comunicar los datos a terceras personas para realizar un tratamiento posterior de los mismos, pudiendo transmitirse, difundirse o realizar cualquier otra forma de habilitación de acceso, cotejo o interconexión a esos datos. Los terceros siempre deberán estar identificados y tener delimitadas sus funciones y responsabilidades.

¿Sabías qué?

La AEPD multó a una empresa bancaria por cobrar comisiones a cambio de no ceder datos personales. [5]

Ciclo de vida de los datos: recogida o generación

5

Finalización / Destrucción

- **Finalización o destrucción**: los datos deben tener un período de retención, el cual está recogido en el principio de limitación de conservación que explicaremos más adelante, y que hace referencia a que los datos solo podrán mantenerse durante el tiempo necesario para lograr la finalidad del tratamiento, sin exceder este periodo. Una vez que este tiempo transcurre, los datos deben eliminarse o destruirse. Este concepto de destrucción es entendido en sentido amplio, ya que no es necesario destruirlos físicamente, sino que solo hace falta destruir el vínculo entre los datos y la persona física propietaria de los mismos para que, en ningún caso se pueda identificar a esta persona.

1 INTRODUCCIÓN

Actores

A continuación, vamos a ver los principales actores que intervienen en el RGPD y en todo lo referente al tratamiento de datos, aunque profundizaremos en cada uno de ellos más adelante:

Figura / Actor	Función
Interesado	Persona física cuyos datos van a ser tratados.
Responsable del tratamiento de los datos	Persona física o jurídica que se encarga de garantizar que el tratamiento de datos se lleva a cabo conforme al RGPD a través de medidas técnicas y organizativas.
Encargado del tratamiento de los datos	Persona física o jurídica que ejecuta y realiza el tratamiento de los datos.
Delegado de Protección de Datos (DPO)	Persona física o jurídica encargada de informar a la entidad responsable o al encargado del tratamiento sobre sus obligaciones legales respecto a la protección de datos.
CISO	Persona responsable de la Seguridad de la Información de la organización.
Autoridad de Control	En España es la Agencia Española de Protección de Datos (AEPD). Vela por el cumplimiento del RGPD.

1 INTRODUCCIÓN

Agencia Española de Protección de Datos (AEPD)

La AEPD, fundada en 1993, como hemos visto, es la encargada de velar por el cumplimiento del RGPD. Se trata de una autoridad de control independiente y con personalidad jurídica propia. En la LOPDGDD, la AEPD se regula en los artículos 44 y siguientes. Esta norma recoge gran cantidad de funciones y poderes que ostenta la AEPD, entre las que podemos destacar:

- Controlar que se aplique y cumpla el RGPD y el resto de normativas en materia de protección de datos.
- Promover la concienciación del público de los riesgos, normas, garantías y derechos en relación con el tratamiento de sus datos.
- Facilitar a cualquier interesado información en relación al ejercicio de sus derechos con respecto al tratamiento de sus datos, previa solicitud.
- Llevar a cabo investigaciones sobre la correcta aplicación del RGPD, así como imponer sanciones por incumplimientos.

1 INTRODUCCIÓN

Agencia Española de Protección de Datos (AEPD)

Saber más: sobre todas las funciones y poderes propios de la AEPD. [6]

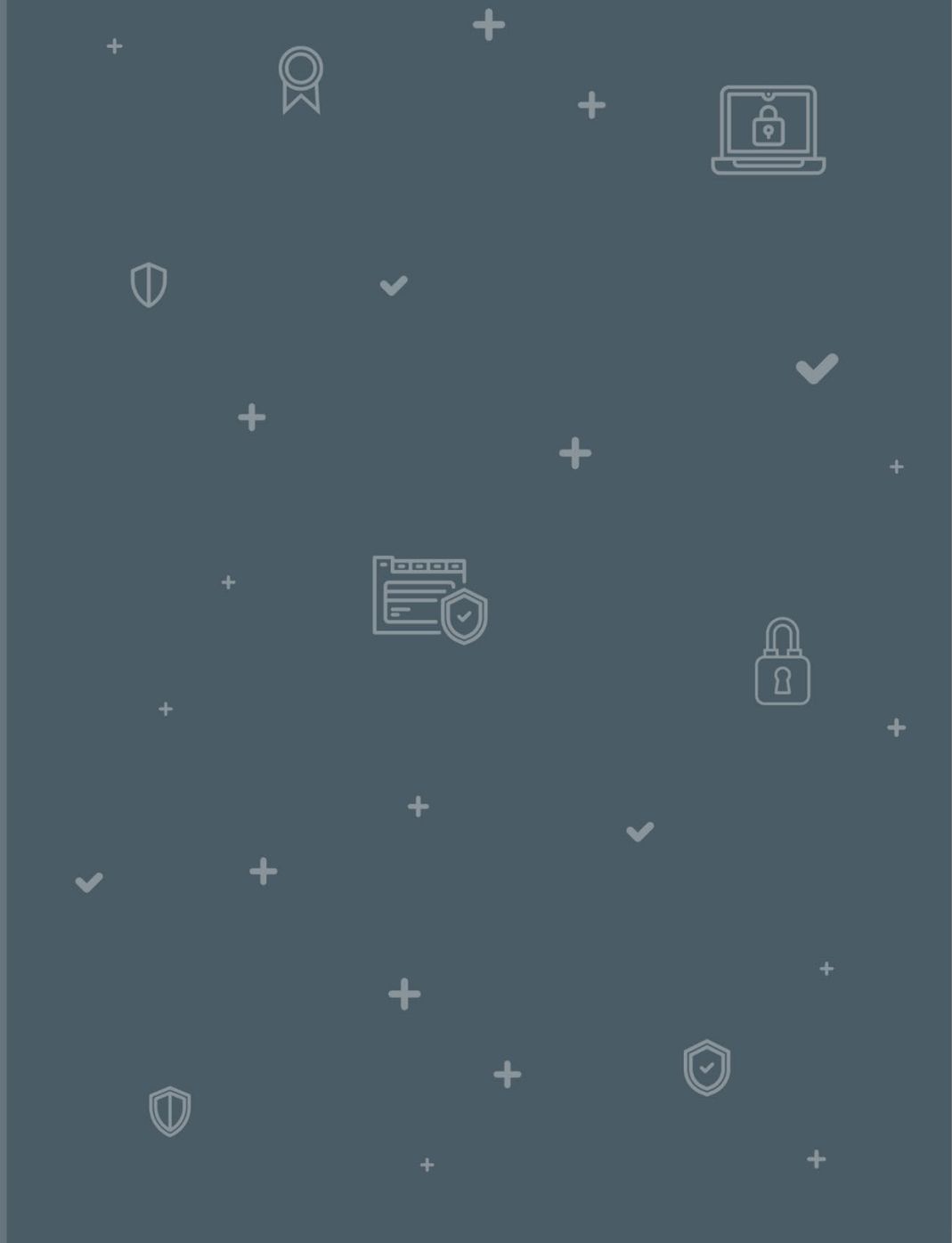
Las organizaciones, en su deber de designar un delegado de protección de datos, deben comunicar a la AEPD la designación, nombramiento y cese de los DPO. La AEPD, por su parte, deberá mantener una lista actualizada de los delegados de protección de datos. Además, el DPO designado actuará como punto de contacto con la AEPD en relación a las cuestiones referentes al tratamiento de datos personales.

Es obligación del responsable del tratamiento de notificar a la AEPD de cualquier violación de seguridad que suponga un riesgo para los derechos y libertades de los interesados y lo hará a través del DPO, en caso de que la organización hubiera designado uno.

Por lo tanto, las organizaciones se comunican con la AEPD a través del DPO y el responsable del tratamiento.

2

LOPD Y RGPD



2 LOPD Y RGPD

Ley Orgánica de Protección de Datos (LOPD)

Como hemos mencionado al principio, vamos a conocer con detalle la Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal (LOPD). La LOPD entró en vigor en el año 2000 para aportar un marco legal en España a la Directiva 45/96/CE del Parlamento Europeo y del Consejo, cuyo objetivo era lograr un equilibrio entre la libre circulación de datos en el ámbito de la Unión Europea y la protección de la vida privada de los ciudadanos. Al tratarse de una directiva, en ella se establecían una serie de objetivos que los Estados miembros tienen que lograr, pero son los países los que deben crear y aplicar sus propias leyes para lograrlo, y, por este motivo, se creó en España la LOPD.

La Directiva Europea también establecía que debía crearse un organismo nacional y autónomo que velase por la protección de datos. En el caso de España, se designó a la **Agencia Española de Protección de Datos** (AEPD) [7] que, aunque existía con anterioridad, fue utilizada para este propósito.

2 LOPD Y RGPD

Reglamento General de Protección de Datos (RGPD)

Sin embargo, tanto la Directiva 45/96/CE del Parlamento Europeo y del Consejo, como la LOPD quedaron obsoletas debido a la evolución y crecimiento del mundo digital, por lo que era necesario actualizarlas, a la par que se introdujeron cambios y novedades que veremos con detalle más adelante.

La antigua Directiva europea proveía de margen de autonomía y actuación a los Estados miembros en materia de protección de datos, por lo que se podían encontrar medidas dispares entre un país y otro. Por ejemplo, en España la transposición de la Directiva 95/46/CE se realizó a través de la LOPD y, en ella, por ejemplo, se establecían las infracciones y sanciones, siendo estas leves, pudiendo ser su cuantía de 601,01€ a 60.101,21€, graves de 60.101,21€ a 300.506,05€ y muy graves de 300.506,05€ a 601.012,10€. Sin embargo, la transposición de la Directiva en el ordenamiento alemán se realizó mediante la Ley Federal de Protección de Datos en la que también se determinan infracciones y sanciones y las establece en dos categorías según el párrafo de la ley en la que se encuentren, pudiendo llegar los del primer párrafo hasta los 25.564€ y las del segundo párrafo hasta los 255.645€.

2 LOPD Y RGPD

Reglamento General de Protección de Datos (RGPD)

Por ello, y para poder adecuarse a las necesidades actuales con el objetivo de reforzar y unificar la protección de los datos de los ciudadanos de la Unión Europea, se creó el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, más conocido como Reglamento General de Protección de Datos (RGPD) que entró en vigor en 2016, siendo de aplicación directa, lo que significa que se integra directamente en los ordenamientos de los Estados miembros de la Unión Europea y produce efectos directos.

Sin embargo, para que España pudiera adecuarse y adaptarse al RGPD y al contexto digital actual, desarrolló la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD), que sustituyó a la antigua LOPD.



2 LOPD Y RGPD

Reglamento General de Protección de Datos (RGPD): novedades

Como hemos mencionado, el RGPD surgió con el objetivo de unificar las reglas aplicables a los Estados miembros en materia de protección de datos, consiguiendo así un mayor control a la vez que permite que las organizaciones y las personas se relacionen en un mercado único digital con libre flujo de los datos personales. El RGPD ha aportado una amplia gama de novedades al ámbito regulatorio de la protección de datos:

- **La necesidad de consentimiento expreso**: desaparece la posibilidad de recabar el consentimiento tácito de los usuarios, siendo preceptiva una declaración inequívoca o una acción afirmativa clara. Todo consentimiento tácito o por omisión deja de considerarse válido.



2 LOPD Y RGPD

Reglamento General de Protección de Datos (RGPD): novedades

- **La figura del Delegado de Protección de Datos (DPD o DPO, por sus siglas en inglés *Data Protection Officer*):** esta persona da apoyo al responsable del tratamiento y en determinados supuestos su designación es obligatoria. Para saber cuándo debemos nombrar un DPD debemos acudir al RGPD y la LOPDGDD. En cualquier caso, siempre es posible su designación voluntaria. Más adelante en la unidad, se verá en profundidad aspectos relacionados con el DPO.



2 LOPD Y RGPD

Reglamento General de Protección de Datos (RGPD): novedades

- **Modificación en la aplicación de las medidas de seguridad:** ya no se establece una lista tasada y genérica de las medidas de seguridad que pueden implementarse, sino que el responsable y el encargado del tratamiento aplicarán las medidas técnicas que crean convenientes en función del riesgo que conlleve un tratamiento concreto. Esto conllevará, además, la obligación de realizar un análisis de riesgos por cada tratamiento.
- **Derechos ARCO-POL:** en la LOPD se establecía los derechos ARCO, mientras que en el RGPD se añaden tres derechos más, lo cual ha dado lugar a los conocidos como derechos ARCO-POL que se otorgan a los usuarios respecto a sus datos personales en relación al acceso, rectificación, cancelación, oposición, portabilidad, olvido y limitación de los mismos.
- **Obligación de notificar los incidentes** que sucedan a la autoridad de protección de datos, que en España se trata de la AEPD (Agencia Española de Protección de Datos).

2 LOPD Y RGPD

Reglamento General de Protección de Datos (RGPD): novedades

- Las **sanciones por el incumplimiento** de la normativa RGPD ascienden hasta 20 millones de euros, en lugar de hasta 600.000€ como se establecía en la LOPD.



¿Sabías qué?

Una empresa bancaria fue multada con 200.000 euros por no aplicar las medidas técnicas y organizativas adecuadas al riesgo que conllevaba el tratamiento de datos. [8]

2 LOPD Y RGPD

Principales diferencias entre LOPD y RGPD

A lo largo de esta unidad profundizaremos en el RGPD y en los aspectos más importantes de este reglamento, sin embargo, es necesario comprender primero las principales diferencias que introduce el RGPD con respecto a la antigua LOPD.

- **Ámbito y los trámites a realizar:**

LOPD	RGPD
Se encargaba de proteger solo a los ciudadanos españoles.	Se encarga de proteger a todos los ciudadanos de la Unión Europea.
Está centrada en los datos personales protegidos.	Incluye los datos genéticos y los datos biométricos.
No es obligatorio comunicar las brechas de seguridad que ocurran.	Es obligatorio comunicar cualquier brecha de seguridad. El incumplimiento puede conllevar una sanción.

2 LOPD Y RGPD

Principales diferencias entre LOPD y RGPD

- **Derechos de los usuarios:**

LOPD	RGPD
Se consideraba válido el consentimiento tácito o por omisión.	Se requiere consentimiento expreso del usuario.
Para la recogida de datos se debía informar al usuario de modo expreso, preciso e inequívoco.	Para la recogida de datos se debe informar al usuario de forma concisa, transparente, inteligible y con un lenguaje claro y sencillo.
Se aplicaban los derechos ARCO (Acceso, Rectificación, Cancelación y Oposición).	A los derechos ARCO se añaden los derechos de Portabilidad, Olvido y Limitación, convirtiéndose en los derechos ARCO-POL o ARSULIPO.

2 LOPD Y RGPD

Principales diferencias entre LOPD y RGPD

- **Obligaciones, procesos y sanciones**:

LOPD	RGPD
Se establecían medidas de seguridad según la sensibilidad de los datos personales.	Se establecen medidas técnicas y organizativas en función del riesgo que conlleve el tratamiento de los datos.
Los responsables de la normativa eran las autoridades.	Es obligatorio nombrar un Delegado de Protección de Datos bajo ciertos supuestos.
No se regula la obligación de notificar los incidentes.	Obligación de notificar de los incidentes a la AEPD.
Se debían realizar auditorías que verificarían la adecuación e idoneidad de las medidas de seguridad.	Se deben llevar a cabo procesos de verificación, evaluación y valoración periódicas para comprobar la eficacia de las medidas.
Las sanciones estaban comprendidas entre 9.000 € y 600.000 €.	Las sanciones ascienden hasta los 20 millones de euros.

2 LOPD Y RGPD

LOPDGDD

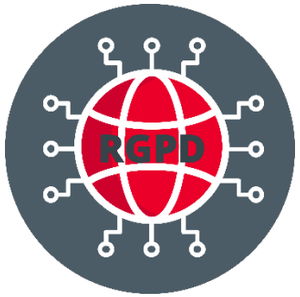
La Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDGDD), sustituye a la antigua LOPD y surge de la necesidad de adaptar el RGPD al ordenamiento interno español. Se encarga del tratamiento de los datos de carácter personal y trata de garantizar que todas las personas puedan tener un mayor control sobre el uso que se hace de sus datos.

Sin embargo, aunque la antigua LOPD quedó derogada por la LOPDGDD, esta última sí mantiene gran parte del texto legal de la LOPD, como, por ejemplo, los derechos del interesado, por lo que se mantienen los antiguos derechos ARCO (Acceso, Rectificación, Cancelación y Oposición), pero se añaden tres nuevos derechos (Portabilidad, Olvido y Limitación), convirtiéndose así en los derechos ARCO-POL.

2 LOPD Y RGPD

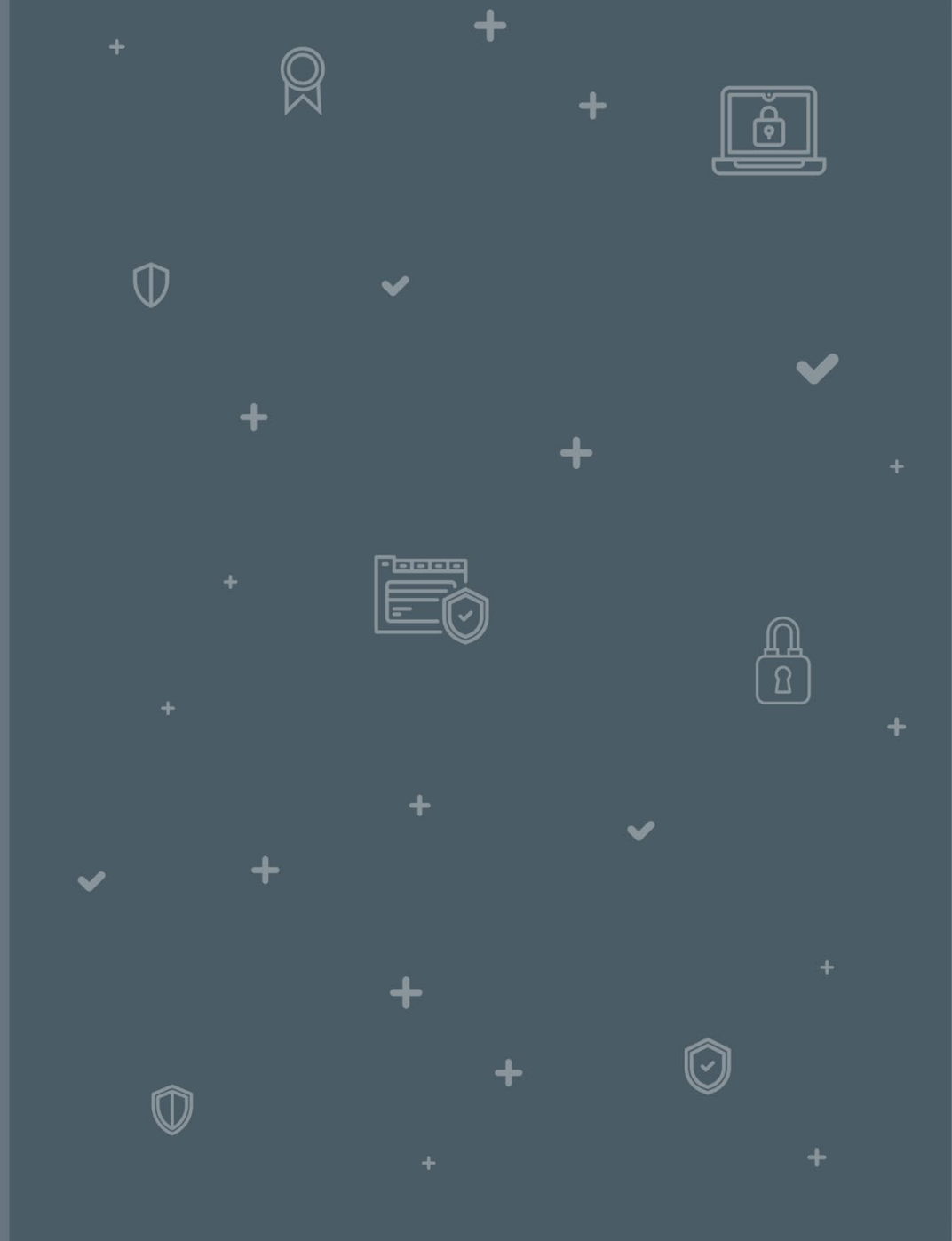
LOPDGDD

Por otro lado, esta nueva ley tiene en cuenta las garantías de los derechos digitales debido al crecimiento de Internet y la realidad del mundo globalizado e hiperconectado en el que vivimos. Por ello, recoge una lista exhaustiva de derechos digitales como medidas de protección para los usuarios, como pueden ser los derechos de neutralidad de Internet y seguridad digital o para la inserción de los usuarios en la sociedad digital, como el acceso universal a Internet y el derecho a la educación digital.



3

RGPD Y ACTUALIZACIÓN DE LOPDGDD



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

El RGDP determina cuál será el ámbito de aplicación del Reglamento, que en su artículo 2 establece que «*se aplica al tratamiento total o parcialmente automatizado de datos personales, así como al tratamiento no automatizado de datos personales contenidos o destinados a ser incluidos en un fichero*» y en su artículo 3 hace referencia a que «*se aplica en el contexto de las actividades de un establecimiento del responsable o del encargado en la Unión, independientemente de que el tratamiento tenga lugar en la Unión o no*».

Por lo tanto, el RGPD se aplicará en los siguientes casos:

- Cuando exista un tratamiento de datos personales, ya sea automatizado o no.
- Si el tratamiento de datos personales recae sobre una persona o personas físicas.
- Independientemente de que el tratamiento se produzca dentro o fuera de la Unión Europea, siempre que el responsable o encargado del tratamiento tenga su establecimiento dentro de la Unión.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

No obstante, será de aplicación el RGPD, aun no encontrándose el establecimiento dentro de la Unión Europea, cuando se traten datos personales de residentes en la Unión Europea y las actividades de tratamiento estén relacionadas con oferta de bienes o servicios a dichos residentes o el control del comportamiento del residente dentro de la Unión Europea.

Por último, será también de aplicación este reglamento cuando el tratamiento de datos sea realizado por parte de un responsable no establecido en la Unión Europea pero sí en un lugar donde sea aplicable el Derecho de los Estados miembros de la Unión, en virtud del derecho internacional público.



¿Sabías qué?

Empresas como Meta, propietaria de Facebook e Instagram, amenazaron con retirar sus servicios de la UE si no se facilita la trasferencia de datos con EE.UU. [9]

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

Por lo tanto, el RGPD se aplicará en dos casos específicos:

- Cuando una empresa o entidad trata datos personales como parte de las actividades de una de sus sucursales localizadas en la Unión Europea, independientemente del lugar donde sean tratados los datos.
- Cuando una organización se encuentre ubicada fuera de la Unión Europea, pero ofrece sus productos y servicios o incluso observa el comportamiento de las personas residentes en el territorio de la Unión Europea.

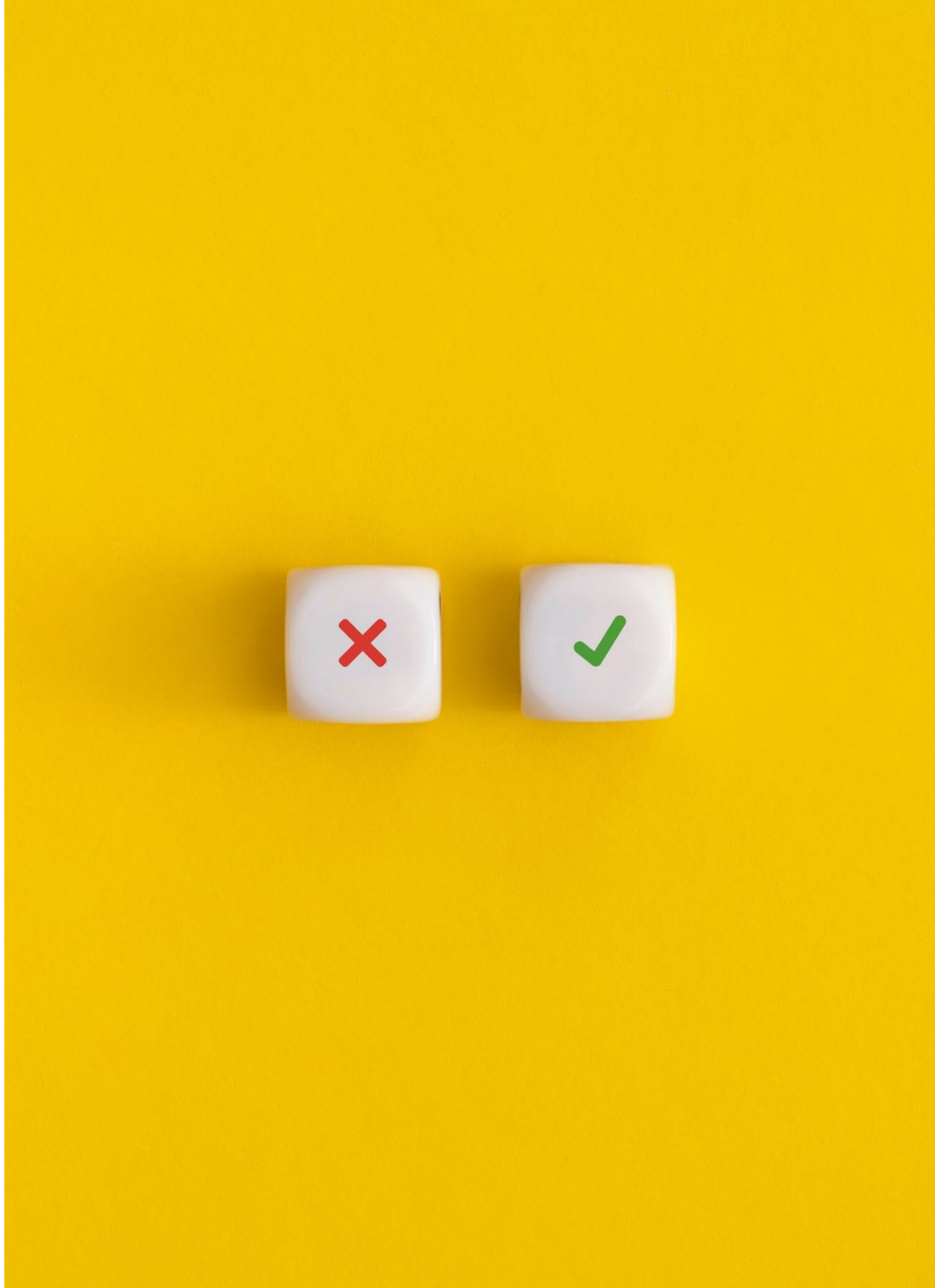
Si el tratamiento de datos personales no constituye la parte principal del negocio de la organización y su actividad no supone un riesgo para las personas, no estará sujeta a algunas de las obligaciones que impone el RGPD, como en el caso del nombramiento de un Delegado de Protección de Datos.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

A continuación, presentamos un breve ejercicio de verdadero / falso para facilitar la comprensión de los conocimientos explicados anteriormente en este apartado:

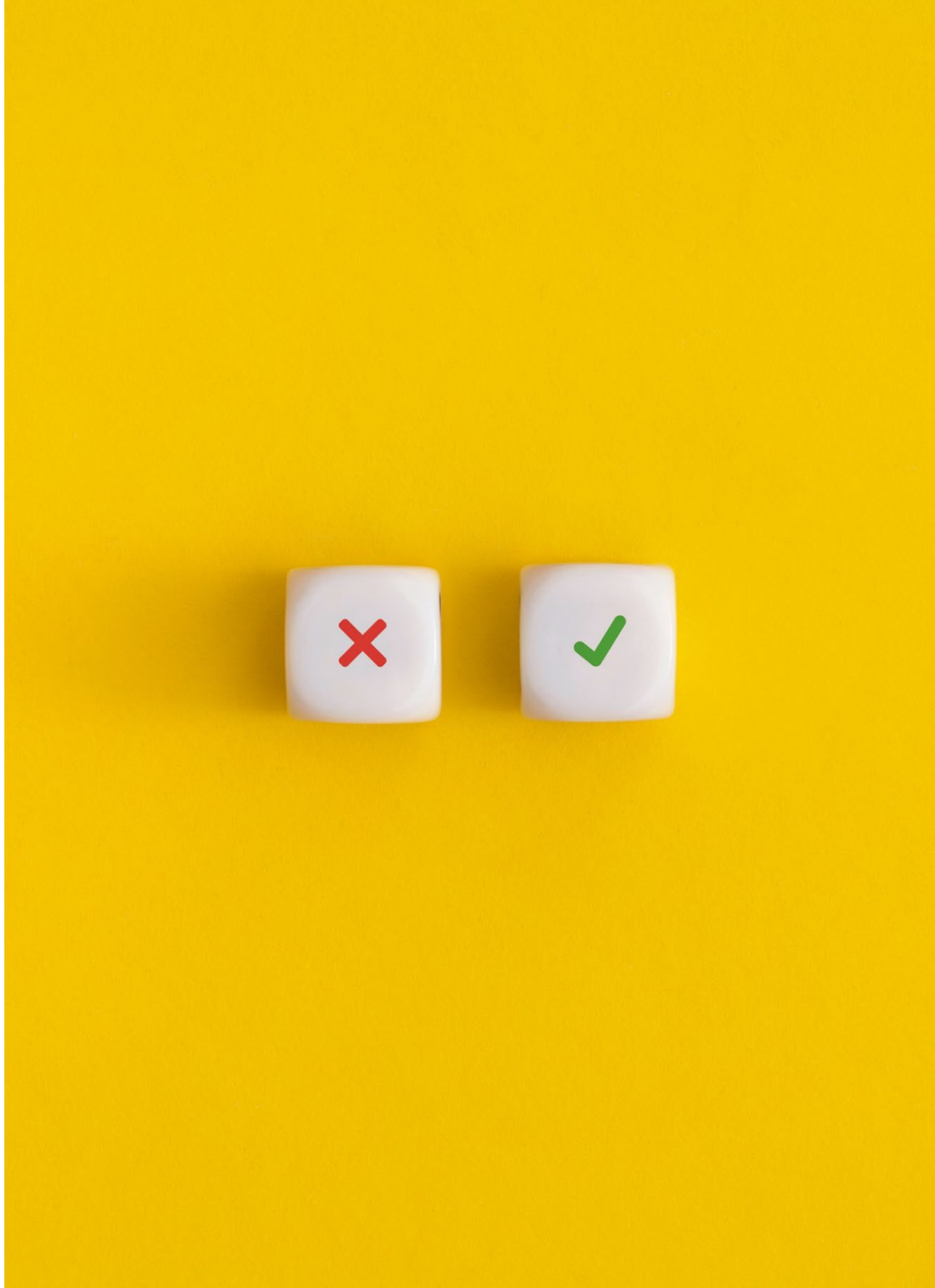
- ¿Sería de aplicación el RGPD a una empresa que está localizada en Marruecos prestando servicios a clientes de Namibia?
- ¿Sería de aplicación el RGPD a una empresa localizada en Estados Unidos que trata datos personales de clientes alemanes a través de su sucursal ubicada en Alemania?



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- ¿Sería de aplicación el RGPD a una empresa que está localizada en Marruecos prestando servicios a clientes de Namibia? **Falso**
- ¿Sería de aplicación el RGPD a una empresa localizada en Estados Unidos que trata datos personales de clientes alemanes a través de su sucursal ubicada en Alemania? **Verdadero**



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

Un aspecto muy relevante es el intercambio y transferencia de datos con países fuera de la Unión Europea, como es el caso de Estados Unidos. Hasta 2020, disponíamos del *Privacy Shield* o "Escudo de privacidad UE-EEUU", un acuerdo firmado en 2016 entre la UE y EE.UU. para garantizar la protección de datos de los usuarios europeos al otro lado del Atlántico, es decir, garantiza que las empresas estadounidenses que recolectan datos de usuarios europeos cumplen con la normativa europea de protección de datos.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

Fue en este año, 2020 cuando el Tribunal de Justicia de Europa anuló este acuerdo a raíz de una denuncia de un abogado austríaco que denunciaba que las leyes estadounidenses no ofrecían la misma protección que el RGPD.

Sin embargo, la Comisión Europea y EE.UU. han acordado el llamado Marco Transatlántico de Privacidad de Datos, que sustituye al *Privacy Shield*. Aún tendrá que desarrollarse el texto legal, pero este marco ha sentado las bases que permitirán de nuevo realizar transferencias de datos entre EE.UU. y la UE.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

El RGPD recoge una serie de principios que los responsables y encargados del tratamiento de datos personales deben tener en cuenta a la hora de realizar dicho tratamiento. Los principios del RGPD suponen un conjunto de enunciados que informan sobre el funcionamiento de las normas y se les atribuye un carácter ético, pues se trata de una serie de valores que dan sentido a las normas y, cuando se incumplen, pueden derivar en sanciones.





3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

Los principios del RGPD se recogen en su artículo 5 y son relativos al tratamiento de los datos. A continuación, los veremos con detalle:

- **Principio de licitud, transparencia y lealtad:** los datos personales deben ser **tratados de manera lícita, leal y transparente** en relación con el interesado. Por ejemplo, un empresario puede ceder los datos personales de uno de sus empleados a una entidad financiera con la finalidad de pagar la nómina. Este caso es lícito y leal porque el empresario necesita llevar a cabo esta acción para ejecutar el contrato para que, adicionalmente, sea trasparente es preciso que el trabajador esté informado del tratamiento que se dará a sus datos y la finalidad del mismo.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- **Principio de finalidad:** los datos serán **recogidos con un fin determinado** y no podrán ser tratados posteriormente con fines incompatibles a aquellos que justificaron su recogida. No se considerará fin incompatible cuando el tratamiento posterior atienda al interés público, a la investigación científica e histórica o a fines estadísticos.

  Por ejemplo, cuando un empleado trabaja en una organización, los datos del empleado no se pueden ceder sin su consentimiento, a una empresa de electricidad para que calcule sus horarios de permanencia en la oficina y le realice una tarifa personalizada para las horas que esté en su casa. Sin embargo, si una investigación judicial descubre que se ha cometido un delito de blanqueo de capitales y es preciso conocer los horarios en los que cada empleado ha estado en la oficina, la cesión de esta información a las autoridades competentes está justificada por el interés público en aras de encontrar a los responsables del delito.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- Se debe regir el **principio de minimización de datos**, es decir, se deberán recoger solo los datos imprescindibles para la consecución de los fines que motivaron su recogida. Por ejemplo, si la organización quiere habilitar el acceso a las instalaciones mediante huella dactilar, deberá recoger la huella dactilar y el nombre completo del empleado. No tendría sentido que solicitara para este fin la fecha de nacimiento, el estado civil o el domicilio.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- **Principio de exactitud:** los datos personales **deben ser exactos**, lo que conlleva la necesidad de actualización continua de los datos tomando medidas razonables para suprimir o rectificar las inexactitudes. Si, por ejemplo, una empresa de compra *online* recoge nuestro domicilio en la calle X y nos mudamos a la calle Y, cuando solicitemos que rectifiquen nuestros datos para que sigamos recibiendo los paquetes a domicilio, la empresa tendrá que rectificarlos para que sean exactos.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- **Principio de limitación del plazo de conservación:** el **plazo de conservación** de los datos debe ser **limitado** en el tiempo, lo que se traduce en que los datos personales serán mantenidos para permitir la identificación de los interesados durante el tiempo imprescindible para la consecución de los fines del tratamiento. Sin embargo, podrán conservarse durante periodos más largos cuando se traten para fines de investigación científica e histórica, de interés público o para fines estadísticos. En estos casos en los que el periodo de conservación es más dilatado será necesario implementar las medidas apropiadas para proteger los derechos del interesado. Por ejemplo, los datos biométricos para acceder a las instalaciones de una organización serán mantenidos solo durante el tiempo en el que sirvan para este propósito; en el momento en el que el empleado cause baja en la empresa, estos datos deben dejar de conservarse. Por el contrario, los datos de contacto del empleado se podrían retener y mantener más tiempo para cuestiones laborales futuras o referentes a la relación laboral pasada.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- **Principio de seguridad:** en este caso, se deben adoptar las medidas técnicas y/o organizativas apropiadas para **garantizar la seguridad de los datos** personales. Las medidas técnicas hacen referencia a cómo se protege la información o datos, mientras que las medidas organizativas hacen referencia a quién puede acceder a esa información o datos, cómo y cuándo. Garantizar la seguridad de los datos hace referencia a la protección de los mismos frente a un tratamiento no autorizado o ilícito y, también, a su pérdida, destrucción o daño accidental. El tratamiento no autorizado o ilícito hace referencia al hecho de que se utilicen los datos de un usuario para unos fines distintos de aquellos para los que fueron recabados, por ejemplo, si se recogen los datos de un usuario para enviarle los pedidos *online* que realice, que no se utilicen esos datos para otro fin, salvo que el usuario hubiera dado su consentimiento.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Ámbitos de aplicación del Reglamento General de Protección de Datos (RGPD)

- Por último, el **principio de responsabilidad activa o responsabilidad demostrada** establece que el Responsable del Tratamiento de los Datos debe mantener una adecuada diligencia en la protección y garantía de los derechos y libertades de las personas físicas cuyos datos son tratados, además de poder demostrar que el tratamiento se ajusta a lo establecido tanto en el RGPD como en la LOPDGDD. Por ello, es importante remarcar que el cumplimiento de todos estos principios **debe poder demostrarse** ante las autoridades por el responsable del tratamiento, por lo que la implementación de los mismos debe ser real.

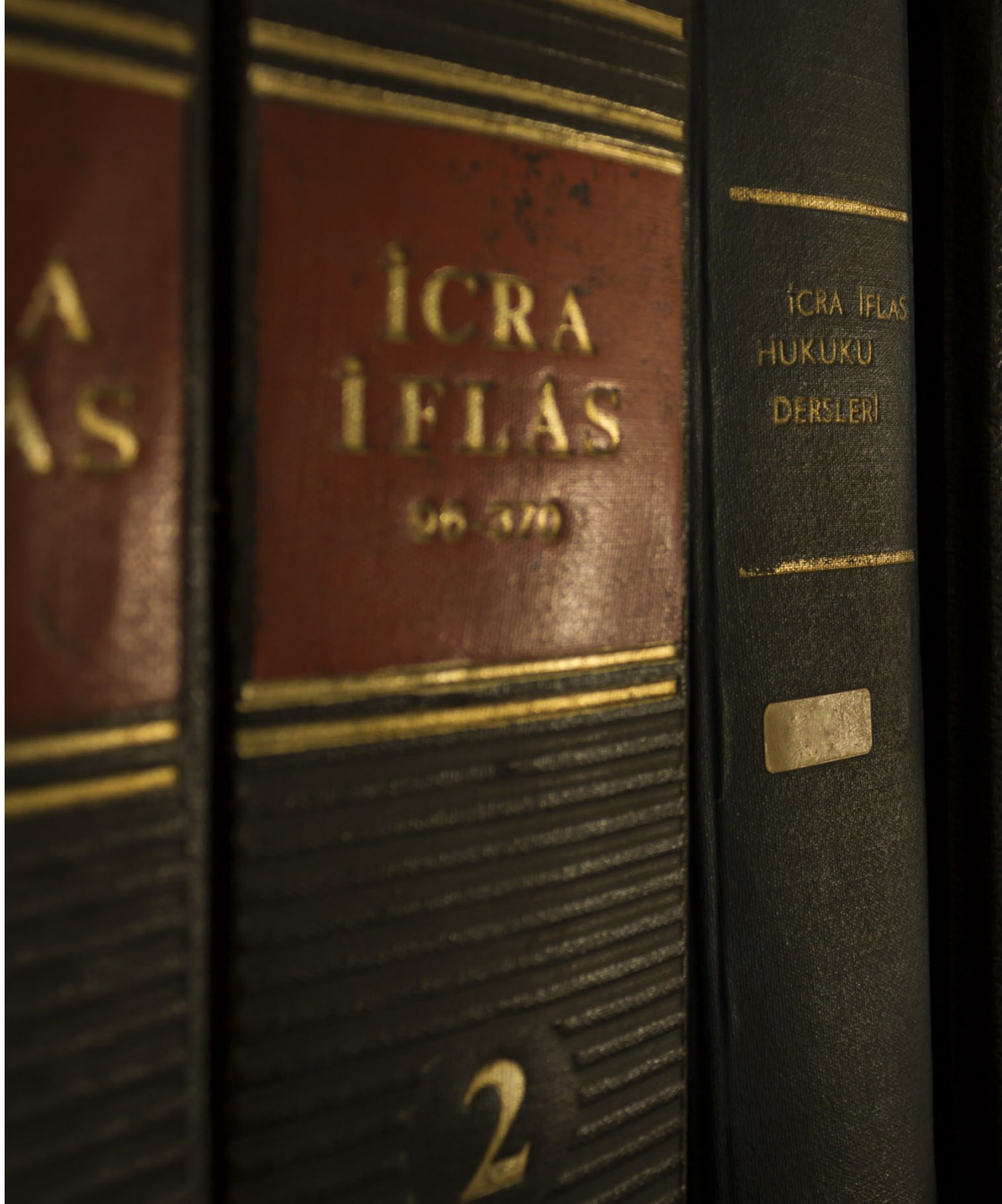


3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Principio de licitud del tratamiento

El artículo 6 del RGPD establece que solo se considerará lícito el tratamiento de datos cuando se cumpla **alguna** de las siguientes condiciones:

- El interesado dio su **consentimiento expreso** para que se realice el tratamiento de sus datos personales, ya sea para uno o varios fines específicos.
- El tratamiento es necesario para la **ejecución de un contrato** del que el interesado es parte o para la aplicación de medidas precontractuales.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Principio de licitud del tratamiento

- El tratamiento es necesario para el **cumplimiento de una obligación legal** aplicable al responsable del tratamiento, para proteger intereses vitales del interesado o de otra persona física, o para el cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos conferidos al responsable del tratamiento. Por ejemplo, sería el caso del tratamiento de los datos personales de los clientes de cualquier comercio para la emisión de una factura o en el tratamiento de los datos personales de una persona en una situación de supervivencia extrema.
- El tratamiento es necesario para **satisfacer intereses legítimos del responsable del tratamiento** o un tercero, siempre que no prevalezcan sobre dichos intereses los intereses, derechos o libertades del interesado. Por ejemplo, el propietario de una página web podrá tratar los datos que los usuarios le hayan facilitado al rellenar un formulario de contacto para poder responder a una consulta.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Principio de licitud del tratamiento

Las condiciones mencionadas son los requisitos básicos que impone el RGPD. Dada la generalidad de los preceptos, el reglamento permite, cuando la necesidad del tratamiento se deba a una obligación legal o derivada de una misión en interés público, que cada Estado miembro introduzca en su ordenamiento jurídico disposiciones específicas para asegurar la licitud del mismo. Por ello, la base para estos dos casos de tratamiento (que se deba a una obligación legal o derivada de una misión en interés público) podrá ser establecida tanto por el derecho de la Unión Europea como por el derecho del Estado miembro que le sea de aplicación al responsable.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Condiciones para el consentimiento de datos personales

Como ya hemos señalado anteriormente, es necesario recabar el consentimiento del interesado cuando se vaya a tratar sus datos personales.

El término «consentimiento» hace referencia a la definición establecida en el artículo 4 del RGPD, pues es «*toda manifestación de voluntad libre, específica, informada e inequívoca por la que el interesado acepta, ya sea mediante una declaración o una clara acción afirmativa, el tratamiento de datos personales que le conciernen*».



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Condiciones para el consentimiento de datos personales

Asimismo, las condiciones para el consentimiento de datos personales están recogidas en el artículo 7 del RGPD y son las siguientes:

- El responsable del tratamiento tiene que poder demostrar que ese consentimiento fue concedido.
- Si el consentimiento del interesado se diese en el contexto de una declaración escrita que trate varios asuntos, la solicitud del consentimiento debe especificar claramente a cuál de esos asuntos se refiere. Nunca será vinculante una parte de esa declaración que infrinja el RGPD, aunque se haya prestado el consentimiento.
- **Tiene que informarse** al interesado de que podrá retirar su consentimiento **en cualquier momento**, según lo redactado en el reglamento, «*será tan fácil retirar el consentimiento como darlo*».

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

El RGPD, en su artículo 9, recoge una lista de datos personales especiales, es decir, aquellos que revelen el origen étnico o racial, las opiniones políticas, las convicciones religiosas o filosóficas, la afiliación sindical y datos genéticos o biométricos dirigidos a identificar de manera unívoca a una persona física, datos relativos a la salud o datos relativos a la vida sexual o la orientación sexual de una persona física.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

El tratamiento de esta categoría especial de datos está prohibido salvo concurrencia de alguna de las siguientes circunstancias:

- El interesado dio su consentimiento explícito, salvo que el derecho de la Unión Europea o de los Estados miembros no permita levantar la prohibición del tratamiento.
- El tratamiento es necesario para el cumplimiento de obligaciones y el ejercicio de derechos, tanto del responsable como del interesado en el contexto del Derecho Laboral y Seguridad y Protección Social, cuando así lo autorice el derecho de la Unión Europea o un convenio colectivo.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

- Cuando «*el tratamiento sea necesario para proteger los intereses vitales del interesado*» o de otra persona física y el mismo no pueda dar su consentimiento por hallarse incapacitado física o jurídicamente. Por ejemplo, si una persona con una discapacidad intelectual necesitase una determinada medicación para salvar su vida, se permitiría el tratamiento de sus datos médicos para comprobar que una nueva pauta de medicación o las intervenciones a las que se haya sometido van a interaccionar con la medicación actual.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

- Cuando el tratamiento se realiza en circunstancias legítimas y con garantías por una fundación, asociación o cualquier otro organismo sin ánimo de lucro, cuya finalidad sea política, filosófica, religiosa o sindical, siempre que el tratamiento se refiera a miembros actuales o antiguos y que no se comunique fuera de ellos sin su consentimiento. Sería el caso, por ejemplo, de la organización de un sindicato que trata los datos sobre opiniones políticas de sus afiliados.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

- Cuando «*el tratamiento se refiere a datos personales que el interesado ha hecho manifiestamente públicos*». Por ejemplo, una persona que comparte sus opiniones políticas a través de las redes sociales.
- «*El tratamiento es necesario para formular, ejercer o defender reclamaciones o cuando los tribunales actúen en el ejercicio de su función judicial*». Por ejemplo, cuando un tribunal esté realizando unas diligencias de investigación y necesite tratar los datos biométricos de un sospechoso para cotejarlos con pruebas halladas en el escenario de un delito.
- «*El tratamiento es necesario por razones de interés público esencial*», sobre la base del derecho de la Unión Europea o de los Estados miembros. Este tratamiento debe ser proporcional al fin perseguido, respetar el derecho a la protección de datos y establecer medidas adecuadas y específicas para proteger los intereses y derechos fundamentales del interesado.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

- «*El tratamiento es necesario para fines de medicina preventiva o laboral, evaluación de la capacidad laboral del trabajador, diagnóstico médico, prestación de asistencia*» o tratamiento de tipo sanitario o social o gestión de los sistemas y servicios de asistencia sanitaria y social, sobre la base del Derecho de la Unión o de los Estados miembros o en virtud de un contrato con un profesional sanitario y sin perjuicio de las condiciones y garantías correspondientes. Sería el caso del tratamiento de datos que se realiza con las revisiones médicas que deben pasar los miembros de las Fuerzas y Cuerpos de Seguridad del Estado para garantizar que pueden seguir ejerciendo su función correctamente.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

- «*El tratamiento es necesario por razones de interés público en el ámbito de la salud pública como la protección frente a amenazas transfronterizas graves para la salud o para garantizar elevados niveles de calidad y de seguridad de la asistencia sanitaria y de los medicamentos sobre la base del Derecho de la Unión Europea o de los Estados miembros y estableciendo así medidas adecuadas para proteger los derechos y libertades del interesado, en particular el secreto profesional*». Por ejemplo, sería el caso del tratamiento y cesión de datos personales relativos al proceso de vacunación frente a la COVID-19.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de categorías especiales de datos personales

- «*El tratamiento es necesario con fines de archivo en interés público, fines de investigación científica o histórica o fines estadísticos*» sobre la base del Derecho de la Unión o de los Estados miembros debiendo ser proporcional al fin perseguido, respetando el derecho a la protección de datos y establecer medidas adecuadas para proteger los intereses y derechos fundamentales del interesado. Por ejemplo, en una investigación científica acerca de la relación entre los hábitos saludables y un mayor desgaste de las articulaciones a partir de los setenta años se debería cumplir este requisito.



  Los Estados miembros de la Unión Europea podrán introducir condiciones o incluso limitaciones adicionales, al tratamiento de datos genéticos, biométricos o relativos a la salud debido a la sensibilidad especial de los mismos.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de datos personales relativos a condenas e infracciones penales

En el artículo 10 del RGDP se establece «*el tratamiento de datos relativo a condenas, infracciones penales y medidas de seguridad, que solo podrá llevarse a cabo bajo la supervisión de las autoridades públicas o cuando lo autorice el Derecho de la Unión o de los Estados miembros y siempre que se aseguren las garantías adecuadas para los derechos y libertades de los interesados*».



Por ejemplo, todas aquellas personas que desarrollen una actividad que suponga un contacto habitual con menores deberán entregar en su centro de trabajo, independientemente de que la organización no sea autoridad pública, el certificado del Registro Central de Delincuentes Sexuales con carácter negativo en base a la Ley 26/2015 de modificación del Sistema de Protección a la Infancia y a la Adolescencia y la Ley 45/2015 de Voluntariado.

3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de datos personales relativos a condenas e infracciones penales

Por otro lado, el artículo 10 de la LOPDGDD establece que «*el tratamiento de los datos personales relativos a condenas e infracciones penales, así como a procedimientos y medidas de seguridad, para fines distintos de los de prevención, investigación, detección o enjuiciamiento de infracciones penales o de ejecución de sanciones penales, solo podrá llevarse a cabo cuando se encuentre amparado en una norma*».

Por ejemplo, una organización no podría exigir a sus candidatos a un puesto de trabajo el Certificado de Antecedentes Penales, salvo en aquellos supuestos excepcionales donde se encuentre expresamente autorizado por una ley. Sin embargo, en el caso de una organización del ámbito aeronáutico, existe una norma europea conocida como Reglamento Europeo sobre Normas comunes para la Seguridad de la Aviación civil que impone la comprobación de antecedentes personales de los empleados que acceden a zonas restringidas de seguridad.



3 RGPD Y ACTUALIZACIÓN DE LOPDGDD

Tratamiento de datos personales que no requiere identificación

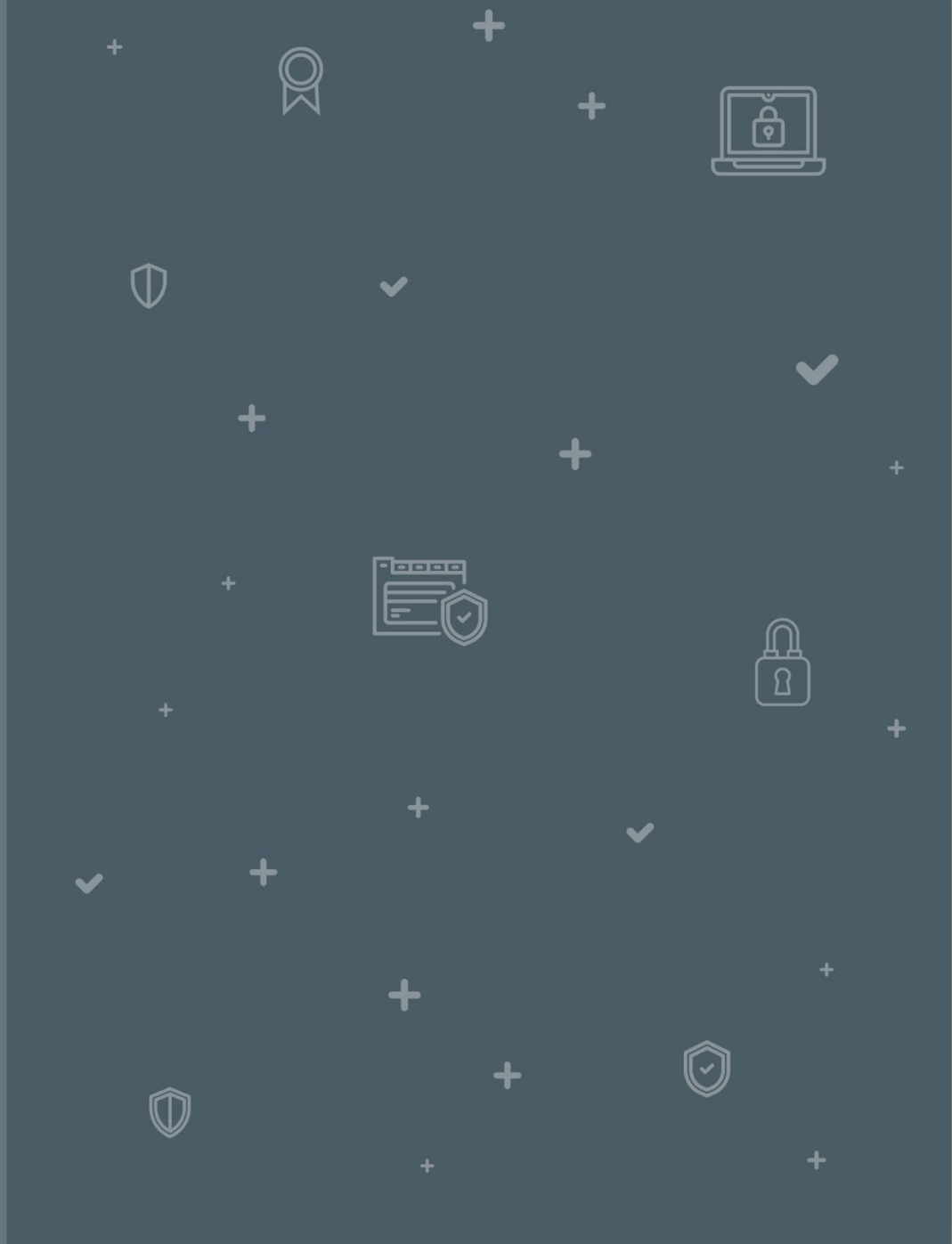


Si los fines para los que el responsable trata los datos personales de un interesado no requieren la identificación de dicho interesado no estará obligado a mantener, obtener o tratar información adicional de su persona. En estos casos, cuando el responsable sea capaz de demostrar que no está en condiciones de identificar al interesado, le informará de ello en la medida de lo posible.

Como los datos que obran en poder del responsable no permiten la identificación del interesado, este no podrá ejercer los derechos de acceso, rectificación, supresión, limitación y portabilidad, salvo que facilite información adicional que permita su identificación.

4

DERECHOS ARCO-POL



4 DERECHOS ARCO-POL

Introducción

Los derechos ARCO-POL, o también llamados ARSULIPO, son el listado de derechos que disponen los interesados respecto del tratamiento de sus datos personales. Estos se encuentran recogidos en los arts. 15 a 21 del RGPD y son los derechos de: Acceso, Rectificación, Cancelación (supresión), Oposición, Portabilidad, Olvido y Limitación. Estos derechos también se recogen en la LOPDGDD, en los artículos 13 a 18.

Los derechos ARCO-POL tienen dos características principales:

- Son **personalísimos**: solo pueden ejercerse por el titular de los datos, su representante legal o su representante voluntario designado específicamente para el ejercicio de alguno de estos derechos.
- Son **independientes**: no es necesario ejercer ninguno de ellos previamente para ejercer otro, sino que cada uno se ejerce por separado.

4 DERECHOS ARCO-POL

Derecho de acceso

El artículo 15 del RGPD, recogido también en el artículo 13 LOPDGDD, establece que el interesado tendrá derecho a saber si sus datos están siendo tratados y, de ser así, derecho a acceder a los mismos y conocer la siguiente información:

- Los fines del tratamiento y las categorías de datos personales tratadas.
- A quiénes se van a comunicar esos datos personales.
- El plazo durante el que se prevé que van a ser conservados los datos personales. De no ser posible determinar un plazo concreto, los criterios utilizados para determinar ese plazo.
- La existencia de los derechos de rectificación, supresión, limitación y oposición al tratamiento. También el derecho a reclamar ante una autoridad de control que, en el caso de España, es la AEPD.

4 DERECHOS ARCO-POL

Derecho de acceso

- De dónde se han obtenido los datos personales del interesado, en caso de que no haya sido él quien los comunicó.
- La existencia de decisiones automatizadas, incluyendo la elaboración de perfiles, así como la importancia y las consecuencias de dicho tratamiento automatizado.



4 DERECHOS ARCO-POL

Derecho de acceso

El interesado podrá solicitar que se le entregue una copia de los datos personales objeto del tratamiento, debiendo pagar un canon razonable por los costes administrativos que ello pueda suponer al responsable. Si el interesado presenta la solicitud de forma telemática, a menos que solicite que se le entregue de otro modo, la información se le facilitará en un formato electrónico de uso común.

Por ejemplo, Juan otorgó el consentimiento para que trataran sus datos personales en una página web, permitiéndole así recibir las compras *online* en su domicilio. Meses más tarde, Juan quiere saber qué tipo de datos está manejando dicha página, con qué finalidad y si esos datos los está cediendo a terceros. Ejerciendo el derecho de acceso, Juan podrá tener acceso a toda esta información.



¿Sabías qué?

La AEPD sancionó a un detective privado con 2.000 euros por no facilitar información al interesado sobre el tratamiento de sus datos. [10]

4 DERECHOS ARCO-POL

Derecho de rectificación

El derecho de rectificación se recoge en el artículo 16 del RGPD y artículo 14 de la LOPDGDD y establece que el interesado tendrá derecho a obtener **sin dilación indebida** la rectificación de los datos personales inexactos que le conciernan. En función del fin del tratamiento, el interesado podrá solicitar que se completen los datos personales que sean incompletos.

El interesado debe justificar qué datos son los que requieren corrección y deberá aportar la documentación justificativa de la rectificación que solicita. Por ejemplo, si Juan cambia de domicilio, podrá requerir a la página web que modifique la dirección para recibir las notificaciones, paquetes o cualquier entrega en su nuevo domicilio, para lo que tendrá que aportar la documentación de su nueva dirección.



4 DERECHOS ARCO-POL

Derecho de supresión

El artículo 17 RGPD (y artículo 15 LOPDGDD) establece que el interesado tendrá derecho a que los datos personales que le conciernen sean suprimidos **sin dilación indebida**. Este derecho no debe confundirse con el derecho al olvido, que veremos más adelante.



4 DERECHOS ARCO-POL

Derecho de supresión

El responsable estará obligado a eliminarlos **sin dilación indebida** en los siguientes casos:

- Cuando los datos personales ya no sean necesarios en relación con los fines para los que fueron recogidos o estén siendo tratados de otro modo.
- Cuando el interesado retire el consentimiento otorgado para el tratamiento de sus datos.
- Cuando el interesado ejerza su derecho de oposición y no prevalezcan otros motivos legítimos para el tratamiento.
- Cuando los datos personales han sido tratados ilícitamente.



4 DERECHOS ARCO-POL

Derecho de supresión

- Para el cumplimiento de una obligación establecida en el Derecho de la Unión Europea o de los Estados miembros que sea de aplicación al responsable del tratamiento.
- Cuando los datos personales se hayan obtenido mediante una oferta de servicios de la sociedad de la información a un menor de edad.

Cuando los datos personales se hayan hecho públicos y el responsable del tratamiento esté obligado a suprimirlos conforme a los supuestos que acabamos de ver, deberá tomar medidas razonables en cuanto a tecnología disponible y su coste para suprimir cualquier enlace a los mismos, así como las copias o réplicas que puedan existir.



¿Sabías qué?

Existen sanciones de 100.000 euros por recuperar datos bloqueados de forma indebida. [11]

4 DERECHOS ARCO-POL

Derecho de supresión

Todas estas obligaciones de supresión no entran en juego y los datos seguirán siendo tratados cuando el tratamiento sea necesario:

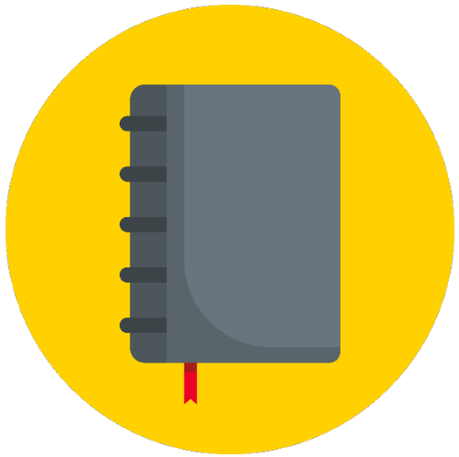
- Para ejercer el derecho a la libertad de expresión e información.
- Para el cumplimiento de una obligación impuesta por el Derecho de la Unión Europea o de los Estados miembros o para el cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos.
- Por razones de interés público en el ámbito de la salud pública.
- Con fines de archivo en interés público, fines de investigación científica e histórica o fines estadísticos y la supresión de los datos hiciesen imposible u obstaculizasen gravemente dicho fin.
- Para la formulación, ejercicio o defensa de reclamaciones.

Por ejemplo, Juan retira su consentimiento para que la página web siga tratando sus datos. En este caso, la página web deberá suprimir los datos de Juan.

4 DERECHOS ARCO-POL

Derecho al olvido

El derecho al olvido no es más que una extensión del derecho de supresión en el marco de los motores de búsqueda de Internet. Este derecho nace a raíz de la persistencia de los datos en la web, por lo que pretende que los datos personales de los usuarios no sean indexados por los buscadores, es decir, se trata de el derecho a impedir que se divulguen datos o información personal a través de Internet, siempre y cuando su publicación no encaje con los principios de adecuación y pertinencia que se prevén en la normativa RGPD.



4 DERECHOS ARCO-POL

Derecho al olvido

Se debe destacar que este derecho no provoca que la página web donde se contiene la información de carácter personal se elimine; sino que los efectos de este derecho al olvido se dirigen de forma exclusiva contra los buscadores de Internet. La página web seguirá existiendo, pero no se podrá relacionar con los datos o información personal del interesado que ejerce este derecho, ya que, cuando se realiza una búsqueda de su nombre o apellidos o información de carácter personal, el buscador de Internet no remitirá a dicha página donde se encuentra la información que se desea «olvidar».



4 DERECHOS ARCO-POL

Derecho al olvido

Por ejemplo, supongamos que el usuario Juan Pérez, alumno del colegio XYZ, ha participado en una competición deportiva, por lo que en la página web de dicho colegio aparece su nombre de forma pública aludiendo a la noticia de la competición.

El derecho al olvido pretende que cuando un usuario busque el nombre de Juan Pérez en un buscador de Internet, no aparezca el resultado de la página web del colegio en el que se habla de la competición deportiva. Esto no quiere decir que la página web desaparezca, ya que seguirá siendo visible para cualquiera que acceda a dicha información por otros medios.



4 DERECHOS ARCO-POL

Derecho al olvido

Sin embargo, si lo que Juan Pérez quiere es que el colegio XYZ elimine sus datos personales de la página web, tendrá que ejercer el derecho de supresión con el colegio, ya que es la institución propietaria de la página web y, por tanto, el responsable de sus publicaciones.

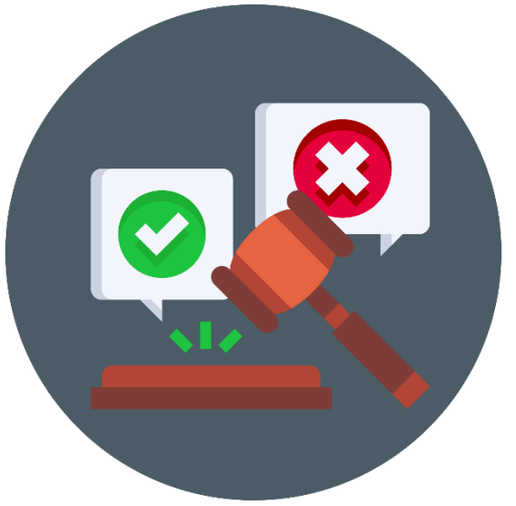


4 DERECHOS ARCO-POL

Derecho al olvido

¿Sabías qué?

La sentencia pionera en España sobre el derecho al olvido ocurrió en 2014 durante un litigio entre Mario Costeja y Google España. El Tribunal de Justicia de la Unión Europea falló en favor de Mario Costeja alegando que el derecho del interesado de que su información personal no estuviera a disposición del público mediante su inserción en un motor de búsqueda, prevaleciendo sobre el interés de las personas a acceder a dicha información.



4 DERECHOS ARCO-POL

Derecho a la limitación del tratamiento

En el artículo 18 RGPD (y el artículo 16 de la LOPDGDD) se prevé la posibilidad de que el interesado limite el tratamiento que se está haciendo de sus datos en circunstancias concretas:

- Cuando el interesado considere que los datos son inexactos y así se lo comunique al responsable del tratamiento. Entonces, se limitará el tratamiento de estos datos hasta que se haya verificado si son o no exactos.
- Cuando el tratamiento sea ilícito, pero el interesado no quiera la supresión de los datos, solo la limitación de su uso.
- Cuando el responsable ya no necesite los datos personales, pero el interesado sí para hacer alguna reclamación.
- Cuando el interesado haya ejercitado el derecho de oposición, mientras se comprueba si prevalecen los intereses del responsable sobre los del interesado.



4 DERECHOS ARCO-POL

Derecho a la limitación del tratamiento

Por ejemplo, una persona puede cambiar de banco y solicitar al antiguo que cierre todas las cuentas que tenía y borre sus datos personales. Sin embargo, según la ley, el banco está obligado a conservar los datos de los clientes durante diez años. En este caso, esta persona podría ejercer su derecho a la limitación del tratamiento con el objetivo de asegurarse de que sus datos no se utilizan para otros fines no deseados.



4 DERECHOS ARCO-POL

Notificaciones

El artículo 19 del RGPD establece que el responsable tiene la obligación de avisar al interesado cuando haga cualquier modificación en sus datos personales, ya sea relativa a la rectificación, supresión o limitación del tratamiento de sus datos. Esta obligación tiene la excepción de que la notificación sea imposible o requiera un esfuerzo desproporcionado.

Por ejemplo, si una persona ejerce su derecho de rectificación para corregir unos datos inexactos de la domiciliación del pago del colegio de su hijo, el colegio como responsable deberá notificar que se ha realizado el cambio o rectificación de estos datos.

Por otro lado, cuando se transfieran datos personales a un tercer país, es decir, un país fuera de la Unión Europea o a una organización internacional, el interesado tendrá derecho a ser informado de las garantías adecuadas que recoge el propio RGPD para estos supuestos.

Saber más: sobre el art. 46 del RGPD. [12]

4 DERECHOS ARCO-POL

Derecho a la portabilidad de los datos

El artículo 20 RGPD (y el artículo 17 LOPDGDD) establece que el interesado tiene derecho a que sus datos personales sean transmitidos de un responsable a otro, es decir, del responsable que actualmente está tratando los datos a otro responsable de su elección cuando dicho tratamiento se realice por medios automatizados.

Por lo tanto, el usuario tiene derecho a decidir quién es el responsable del tratamiento de sus datos personales y a cambiar de responsable si así lo desea. Esto se realizará en base al consentimiento del interesado para fines específicos y la ejecución de un contrato con el interesado.



4 DERECHOS ARCO-POL

Derecho a la portabilidad de los datos

Sin embargo, el derecho de portabilidad no se aplicará en caso de que sea técnicamente imposible realizar la transmisión, de que pueda impactar de forma negativa a los derechos y libertades de terceros o de que el tratamiento tenga una misión de interés público y esté fundamentado en la legislación vigente.



4 DERECHOS ARCO-POL

Derecho a la portabilidad de los datos

El primer responsable podrá conservar los datos cuando dicha conservación sea necesaria para cumplir alguna obligación legal, en caso contario, deberá eliminarlos.

Por ejemplo, si una persona tiene contratada la línea telefónica con la empresa Telefonía123 y quiere cambiarse de compañía a la empresa TodoMóviles, puede solicitar a Telefonía123 que transmitan todos los datos que tengan sobre él a TodoMóviles.



4 DERECHOS ARCO-POL

Derecho de oposición

En el artículo 21 RGPD y artículo 18 LOPDGDD se establece que el interesado tendrá derecho a oponerse a que traten sus datos personales y el responsable deberá cesar dicho tratamiento salvo que se acrediten determinados motivos.

El derecho de oposición se puede solicitar cuando:

- El tratamiento se base en una misión de interés público o legítimo, salvo que el responsable acredite motivos que prevalezcan sobre los intereses, derechos y libertades del interesado.
- El tratamiento tenga fines publicitarios.



4 DERECHOS ARCO-POL

Derecho de oposición

Un ejemplo sería cuando una persona realiza una compra en una tienda *online* y otorga el consentimiento para que le envíen comunicaciones comerciales o publicitarias. Si esta persona desea dejar de recibir estas comunicaciones, puede lograrlo ejerciendo el derecho de oposición. Sin embargo, esto no quiere decir que retire su consentimiento para que la tienda *online* deje de tratar sus datos, sino que deje de tratarlos con fines publicitarios.

¿Sabías qué?

La AEPD sancionó a una compañía aérea con 30.000 euros por no permitir a los usuarios oponerse al uso de *cookies.* [13]

4 DERECHOS ARCO-POL

Derecho ARCO-POL

Las siguientes imágenes enlazan a unos breves vídeos realizados por la AEPD sobre los diferentes derechos de los interesados en materia de protección de datos y cómo ejercerlos.



¿Cuáles son tus derechos de protección de datos?



¿Cómo puedes ejercer tus derechos de protección de datos?

5

FIGURAS RELEVANTES

5 FIGURAS RELEVANTES

El encargado y el responsable del tratamiento de datos

El encargado y el responsable del tratamiento son dos de las figuras más relevantes dentro del RGPD, sin embargo, se trata de dos figuras distintas con funciones diferentes.

Recogido en el artículo 4.8 RGPD se establece que **el encargado del tratamiento** de datos personales es aquella «*persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento*», es decir, es aquella persona que ejecuta y realiza el tratamiento de datos por cuenta del responsable siguiendo las directrices que éste le indica.



5 FIGURAS RELEVANTES

El encargado y el responsable del tratamiento de datos

Por otro lado, recogido en el artículo 4.7 RGPD, se establece que el **responsable del tratamiento** es «*la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros*».

Por lo tanto, se trata de aquella persona que se encarga de aplicar las medidas técnicas y organizativas apropiadas para garantizar que el tratamiento de datos se está llevando a cabo conforme al RGPD, y esto se garantiza a lo largo de todo el ciclo de vida de los datos, desde su recolección hasta su eliminación; esto es, define el «por qué» y el «cómo» deberán tratarse los datos. Estas medias podrán ser actualizadas cuando sea necesario.

5 FIGURAS RELEVANTES

El encargado y el responsable del tratamiento de datos

Respecto de las **obligaciones del responsable**, recogidas en el artículo 24 y siguientes del RGPD y 28 y siguientes de la LOPDGDD, este debe llevar un registro de las actividades del tratamiento, informar a los usuarios cuyos datos serán tratados, así como la necesidad de recabar el consentimiento expreso de los mismos, realizar auditorías y evaluaciones de impacto de protección de datos, designar un Delegado de Protección de Datos cuando se requiera y notificar cualquier brecha de seguridad que ocurra.

Profundizaremos en estas obligaciones más adelante, en el apartado de las medidas de cumplimiento del RGPD.

Además, conforme a los artículos 12, 13 y 14 del RGPD y artículos 11 y 12 de la LOPDGDD, el responsable del tratamiento está obligado a informar de manera concisa, transparente, inteligible y de fácil acceso, con un lenguaje claro y sencillo, de todos los medios a disposición del titular de los datos para ejercer sus derechos que incluyen desde poner en su conocimiento los derechos que le asisten (derechos ARCO-POL), hasta el contacto del delegado de protección de datos de la entidad correspondiente ante quién ejercerlos.

5 FIGURAS RELEVANTES

El encargado y el responsable del tratamiento de datos

Por otro lado, el **encargado del tratamiento** de los datos personales también ostenta una serie de obligaciones, recogidas en el artículo 28 RGPD y el artículo 28 y siguientes de la LOPDGDD, que tienen el objetivo, no solo de cumplir con la normativa, sino de respetar el principio de responsabilidad proactiva; y se agrupan según sean organizativas o de seguridad:

- **Organizativas**:
  - Tratar los datos personales según las instrucciones del responsable y debe asistir al responsable en el cumplimiento de sus obligaciones.
  - No utilizar los datos con fines distintos a los establecidos.

5 FIGURAS RELEVANTES

El encargado y el responsable del tratamiento de datos

- De **seguridad**:
  - No declarar, transmitir, ceder o comunicar datos personales a terceros.
  - Garantizar que todas aquellas personas que estén autorizadas para tratar los datos respeten la confidencialidad de los mismos.
  - Adoptar todas aquellas medidas técnicas y organizativas de acuerdo a las normativas, ya sean internacionales o nacionales.
  - Llevar a cabo la destrucción o devolución de los datos personales así como sus soportes.
  - Conservar los datos que puedan ser utilizados para demostrar el cumplimiento de sus obligaciones, así como para realizar auditorías o inspecciones.

5 FIGURAS RELEVANTES

Delegado de Protección de Datos (DPO)

Un Delegado de Protección de Datos (DPD o DPO, por sus siglas en inglés *Data Protection Officer*) es aquella persona encargada de informar al responsable o al encargado del tratamiento acerca de sus obligaciones legales relativas a la protección de datos. El DPO es el encargado de supervisar el cumplimiento normativo y cooperar con la autoridad de control pertinente. Por lo tanto, es el puente de unión entre el responsable del tratamiento de datos y la autoridad de control. La regulación del DPO se encuentra en el artículo 37 y siguientes del RGPD y en el artículo 34 y siguientes de la LOPDGDD.



5 FIGURAS RELEVANTES

Delegado de Protección de Datos (DPO)

No en todos los casos es obligatorio nombrar un DPO, siendo solo necesario cuando:

- La actividad desarrollada consista en operaciones de tratamiento que requieran una observación habitual y sistemática de interesados a gran escala.
- La actividad desarrollada consista en el tratamiento a gran escala de categorías especiales de datos personales (datos de salud, orientación sexual, raza, opinión política, etc.) y de datos relativos a condenas e infracciones penales.
- Cuando así lo exija el Derecho de la Unión Europea o los Estados miembros.

5 FIGURAS RELEVANTES

Delegado de Protección de Datos (DPO)

Si finalmente se nombra a un DPO, sus datos de contacto deberán ser publicados y se comunicarán a la autoridad de control correspondiente.

Entre las funciones y obligaciones del DPO, recogidas de forma mínima en el artículo 39 del RGPD, se pueden destacar las siguientes:

- Mantener el secreto o la confidencialidad en el desempeño de sus funciones.
- Reportar directamente al más alto nivel jerárquico del responsable o encargado de tratamiento.
- Informar y asesorar, en materia de protección de datos, a todos los empleados que lo requieran, así como atender las consultar de los interesados en materia del tratamiento de sus datos o respecto al ejercicio de sus derechos.
- Supervisar que la entidad cumpla con el RGPD, la LOPDGDD y las políticas que ellos mismos hayan elaborado relativas a protección de datos.

5 FIGURAS RELEVANTES

Delegado de Protección de Datos (DPO)

- Supervisar las auditorías relacionadas con protección de datos.
- Supervisar la concienciación y formación que se imparte a los empleados que vayan a participar en operaciones de tratamiento de datos.
- Cooperar con la autoridad de control (AEPD) y otras agencias autonómicas.



¿Sabías qué?

La AEPD impuso una multa de 25.000 euros a una organización por no disponer de la figura DPO. [14]

5 FIGURAS RELEVANTES

Responsable de Seguridad de la Información CISO - *Chief Information Security Officer*

Asimismo, otra figura importante a destacar ante la llegada de la ISO 27001 es la del CISO, que es el encargado de la seguridad de la información de una organización al desarrollar políticas de seguridad de la información, entre las que se incluyen responsabilidades respecto a la privacidad de la información.

El CISO implementa las medidas, especialmente técnicas, de protección de datos en coordinación con el Delegado de Protección de Datos, que veremos más adelante.



5 FIGURAS RELEVANTES

Ejemplo: Quién es quién en el tratamiento de datos personales en los centros educativos

Interesado

- Es la **persona física titular** (propietaria) de los datos personales.
- Los datos **pertenecen** únicamente **a cada persona** física identificada o identificable a la que se refieren (alumnado, profesorado, progenitores, personal de administración y servicios, proveedores, etc.).
- Si los datos tratados corresponden a menores de 14 años, sus progenitores o tutores legales, en su caso, prestarán el consentimiento en su nombre, pero los datos personales son de los/las menores.



5 FIGURAS RELEVANTES

Ejemplo: Quién es quién en el tratamiento de datos personales en los centros educativos

Responsable
(del tratamiento de los datos)

- Persona física o jurídica, autoridad pública, servicio u organismo que **determina los fines y medios de tratamiento que se realiza.**
- En los **centros educativos públicos** el responsable sería la Administración Educativa (Consejería de Educación de la Comunidad Autónoma). Para los centros de Ceuta y Melilla y los del exterior, el responsable es el Ministerio de Educación y Formación Profesional.
- En el caso de los **centros concertados y privados**, el responsable sería el propio centro educativo (fundación, congregación religiosa, cooperativa, etc.).

5 FIGURAS RELEVANTES

Ejemplo: Quién es quién en el tratamiento de datos personales en los centros educativos

Encargado
(del tratamiento de los datos)

- Persona física o jurídica, autoridad pública, servicio u organismo **que trata los datos por cuenta del responsable.**
- El responsable determina a quién le encarga el tratamiento que se va a llevar a cabo. Debe ser elegido por este únicamente **entre los que ofrezcan garantías suficientes** de cumplimiento de la normativa de protección de datos.
- **El encargado siempre debe actuar en el marco de las instrucciones fijadas por el responsable.**
- **El flujo de datos personales entre el responsable y el encargado no constituye una cesión de datos.**
- Siguiendo el ejemplo, los encargados en el ámbito educativo serían: prestadores de servicios tecnológicos, empresas que gestionan el comedor escolar, la ruta escolar, las actividades extraescolares, etc.

5 FIGURAS RELEVANTES

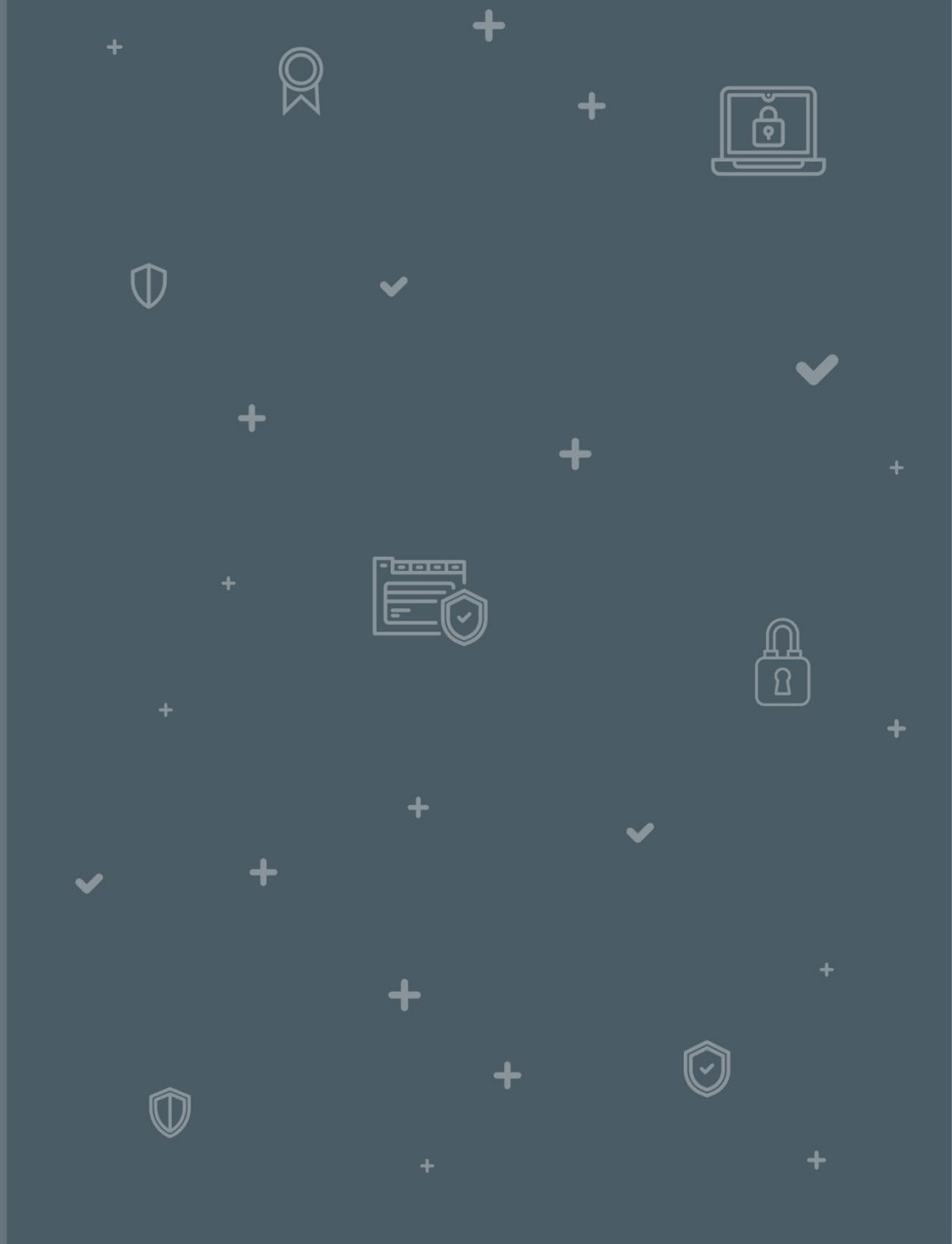
Ejemplo: Quién es quién en el tratamiento de datos personales en los centros educativos

Delegado de protección de datos (DPD)

- Figura que debe designar el responsable de **forma obligatoria** para todos los centros educativos que ofrecen enseñanzas en cualquiera de los niveles establecidos en la legislación reguladora del derecho a la educación.
- **Funciones**, entre otras:
  - **Asesorar e informar** al responsable sobre la aplicación de la normativa de protección de datos y supervisar su cumplimiento.
  - **Intermediar** con las personas afectadas para cuestión de protección de datos, lo que incluye **dudas**, **quejas** y **reclamaciones**.
- En el caso de centros de titularidad pública será nombrado por la Administración Educativa correspondiente, en el caso de centros privados y concertados, será nombrado por el propio centro educativo.

6

MEDIDAS DE CUMPLIMIENTO



6 MEDIDAS DE CUMPLIMIENTO

Introducción

Para garantizar el cumplimiento en materia de protección de datos que se recoge en el RGPD, el mismo establece una serie de medidas de cumplimiento que los responsables del tratamiento y, en ocasiones los encargados, deben llevar a cabo. Algunas de estas medidas son:

- **Análisis de riesgo**
- **Registro de actividades del tratamiento**
- **Protección de los datos desde el diseño y por defecto**
- **Medidas de seguridad**
- **Notificación de brechas de seguridad**
- **Evaluación de impacto de la protección de datos**
- **Designación de un Delegado de Protección de Datos**

6 MEDIDAS DE CUMPLIMIENTO

Análisis de riesgo

El RGPD establece el deber de adoptar las medidas de responsabilidad necesarias en base a los riesgos que el tratamiento de los datos personales pueda suponer para los derechos y libertades de los interesados. La normativa no recoge una lista cerrada de los riesgos, sino que será el responsable quien deba realizar una evaluación de los riesgos existentes para el tratamiento de acuerdo a diversos criterios como la naturaleza, el alcance y el fin del mismo. Algunos de los riesgos podrían ser el compromiso de las categorías especiales de datos, daños sociales o materiales, robo de identidad, etc.

Por ello, el responsable del tratamiento debe realizar la valoración de los riesgos que supone el tratamiento llevando a cabo la identificación y evaluación de los mismos con el fin de poder adoptar las medidas de mitigación adecuadas que garanticen y demuestren la protección de estos derechos y libertades. Por ejemplo, si una organización almacena los datos personales de sus clientes para su tratamiento en un CPD (Centro de Procesamiento de Datos), algunos de los riesgos serían sufrir un acceso no autorizado, un incendio o inundación en el CPD, etc.

6 MEDIDAS DE CUMPLIMIENTO

Evaluación del Impacto de la Protección de Datos (EIPD)

Una Evaluación del Impacto de la Protección de Datos (EIPD) o DPIA (del inglés, *Data Protection Impact Assessment*), recogida en el artículo 35 del RGPD, hace referencia a aquella evaluación de impacto relacionada con la privacidad, cuya finalidad es la identificación y análisis sobre cómo la privacidad de los datos puede verse afectada por determinadas acciones y/o actividades.

Se trata de que el responsable del tratamiento realice un análisis de los riesgos que los diferentes productos y servicios utilizados para el tratamiento de datos pueden suponer para el derecho a la protección de datos de los interesados. Tras el análisis y el estudio de su resultado, se debe realizar una gestión de dichos riesgos adoptando las medidas de protección necesarias que eliminen o mitiguen los mismos.

6 MEDIDAS DE CUMPLIMIENTO

Evaluación del Impacto de la Protección de Datos (EIPD)

Aunque es recomendable analizar los posibles riesgos que pueda conllevar un tratamiento, se debe tener en cuenta que la realización de una evaluación de impacto de la protección de datos no es siempre obligatoria. No obstante, será la autoridad de control (AEPD) quien establecerá y publicará una lista de los tipos de operaciones de tratamiento que necesitan una evaluación de impacto. [15]



6 MEDIDAS DE CUMPLIMIENTO

Evaluación del Impacto de la Protección de Datos (EIPD)

El RGPD establece que la evaluación de impacto sea obligatoria cuando exista:

- **Alto riesgo**: si el tratamiento que se va a realizar conlleva un alto riesgo para los derechos y libertades de las personas físicas. Por ejemplo, si se trata de información confidencial de los interesados.
- **Evaluación sistemática**: si implica la evaluación de aspectos personales de forma sistemática dado que se trata de un tratamiento automatizado como en el caso de la elaboración de perfiles. La elaboración de perfiles consiste en evaluar ciertos aspectos del interesado para poder analizar o predecir sus intereses, su comportamiento u otros aspectos.
- **Tratamiento a gran escala de datos especialmente protegidos**: si el tratamiento a gran escala es referente a categorías especiales de datos, datos personales relativos a condenas e infracciones penales y aquellos datos personales relativos a menores.

6 MEDIDAS DE CUMPLIMIENTO

Evaluación del Impacto de la Protección de Datos (EIPD)

- **Uso de tecnologías invasivas**: hace referencia a aquellas tecnologías que por sus características o funcionamiento suponen una invasión de la privacidad, tales como la videovigilancia a gran escala, los drones, la geolocalización, etc.

Por ejemplo, si una empresa farmacéutica realiza un tratamiento de datos personales a gran escala y, además, trata de información sensible relativa a la salud, será obligatoria la realización de una Evaluación del Impacto de la Protección de Datos personales.

Sin embargo, si la empresa es un pequeño comercio local que únicamente realiza un tratamiento de datos personales básicos de sus clientes, no será obligatoria la realización de la EIPD; aunque siempre es recomendable para garantizar un perfecto cumplimiento del RGPD.

6 MEDIDAS DE CUMPLIMIENTO

Evaluación del Impacto de la Protección de Datos (EIPD)

En el apartado 7 del artículo se hace referencia al contenido mínimo de la EIPD, que deberá contener una descripción de las operaciones referentes al tratamiento y los fines del mismo, una evaluación de la necesidad y proporcionalidad del tratamiento con respecto a su finalidad, una evaluación de los riesgos para los derechos y libertades de los interesados y, por último, las medidas previstas para afrontar los riesgos, abarcando así las garantías, medidas y mecanismos de seguridad que garanticen la protección de los datos de los interesados.



6 MEDIDAS DE CUMPLIMIENTO

Protección de datos desde el diseño y por defecto

Esta medida de cumplimiento se recoge en el artículo 25 RGPD. La protección de datos desde el diseño hace referencia a la adopción de todas aquellas medidas técnicas y organizativas que se deben aplicar con anterioridad al inicio del tratamiento de los datos y a lo largo del ciclo de vida de los mismos, es decir, hace referencia a la aplicación de medidas de protección de los datos y de aquellos productos y servicios que impliquen el tratamiento de datos personales; todo ello con objetivos preventivos, pretendiendo así evitar posibles daños, tanto a las personas físicas como para la organización.

Además, el principio de protección de datos por defecto establece que los responsables tienen la obligación de adoptar aquellas medidas que garanticen el tratamiento únicamente de aquellos datos que sean necesarios para garantizar el cumplimiento de la finalidad del tratamiento, esto es, la minimización de los datos (la mínima cantidad de datos personales, la mínima extensión del tratamiento, el mínimo plazo de conservación de los datos y la mínima accesibilidad a los mismos).

6 MEDIDAS DE CUMPLIMIENTO

Protección de datos desde el diseño y por defecto

Siguiendo con el ejemplo anterior, si los datos personales se van a almacenar en un CPD, se deben adoptar las medidas de protección del CPD antes de comenzar con el tratamiento y durante todo él hasta su finalización. Además, solo se deberán tratar aquellos datos que realmente sean necesarios para la finalidad del tratamiento; por ejemplo, si el tratamiento es para contratar una póliza de seguros, la organización no necesita saber cuál es la afiliación sindical del interesado.



6 MEDIDAS DE CUMPLIMIENTO

Medidas de seguridad

El RGPD, en su artículo 32, establece la obligación de los responsables de determinar y establecer aquellas medidas de seguridad técnicas y organizativas que garanticen un adecuado y apropiado nivel de seguridad en función del riesgo detectado en la valoración de los riesgos previamente realizada. Algunos de los aspectos a tener en cuenta a la hora de establecer estas medidas de seguridad son el coste de la técnica, de su aplicación y la naturaleza, el alcance, el contexto y los fines del tratamiento de los datos, así como los riesgos existentes para los derechos y las libertades de las personas.

Se trata de garantizar la seguridad del tratamiento con el objetivo de evitar la pérdida de los datos, su alteración ilícita o el acceso no autorizado a dichos datos. Siguiendo con el ejemplo, establecer controles de acceso a la sala CPD, medidas de autenticación, etc., pueden ayudar a asegurar los datos personales.

¿Sabías qué?

La AEPD impuso una multa de 9,94 millones de euros por insuficiencia en las medidas de seguridad de una organización a la hora de expedir duplicados de la tarjeta SIM de dispositivos móviles. [16]

6 MEDIDAS DE CUMPLIMIENTO

Notificación de brechas de seguridad

El RGPD recoge como brechas de datos todos aquellos incidentes que supongan «*la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles […] de ocasionar daños y perjuicios físicos, materiales o inmateriales*».

Por ello, se establece en los artículos 33 y 34 RGPD, la obligación del responsable del tratamiento de notificar a la autoridad de control pertinente cualquier brecha de datos que se produzca, a excepción de que dicha brecha no suponga un riesgo para los derechos y libertades de las personas afectadas. En el caso de España, la autoridad de control es la AEPD.

La notificación deberá hacerse a la AEPD en el margen de 72 horas desde que el responsable tuvo conocimiento de la brecha de seguridad y debe incluir un contenido mínimo como la naturaleza del incidente, las categorías de datos y de interesados que se han afectado, las medidas que ha adoptado el responsable para mitigar el incidente y, en caso de que proceda, aquellas para mitigar el impacto negativo sobre los interesados.

6 MEDIDAS DE CUMPLIMIENTO

Notificación de brechas de seguridad

¿Sabías qué?

La AEPD dispone de una herramienta y un formulario *online* para notificar brechas de seguridad. [17]

Se debe tener en cuenta que la valoración del riesgo de la brecha de datos se realiza en base a las características de la brecha, el tipo de datos afectados o el tipo de consecuencias que la brecha pueda tener para los afectados y causar un daño en sus derechos y libertades. Cuando el riesgo sea alto, además de notificar a la autoridad de control, se deberá notificar a los afectados con el objetivo de que estos puedan tomar medidas para protegerse del incidente.

Sin embargo, no será necesario notificar a los interesados cuando el responsable hubiera tomado las medidas adecuadas con anterioridad o posterioridad a la brecha de seguridad y se garantice que no es posible que exista un alto riesgo y cuando la notificación requiera un esfuerzo desproporcionado, para lo cual se establecerá una comunicación pública.

6 MEDIDAS DE CUMPLIMIENTO

Notificación de brechas de seguridad

Siguiendo con el ejemplo anterior, si la organización sufriera un incidente de seguridad a raíz de un acceso no autorizado, deberá notificar a la AEPD dicho incidente y, en caso de que se hayan sustraído o filtrado las contraseñas de los clientes, se les deberá notificar también, a no ser que se cumpla alguno de los supuestos anteriores.



¿Sabías qué?

Según un estudio realizado por *Risk Based Security* (2020), se notificaron alrededor de 4.000 brechas de seguridad, en las que se fugaron 37 billones de registros de datos. [18]

6 MEDIDAS DE CUMPLIMIENTO

Registro de actividades del tratamiento

Con la LOPD era obligatorio notificar a la AEPD acerca de la inscripción de ficheros personales que una organización podía gestionar. Sin embargo, con el RGPD esta obligación desaparece, sin perjuicio de la obligación de registrar las actividades de tratamiento.

Para garantizar la conformidad y cumplimiento del RGPD, los responsables deben llevar un registro de actividades de todos los tratamientos que se están realizando bajo su mando y esta obligación se encuentra recogida en el artículo 30 RGPD y en el artículo 31 LOPDGDD. Se trata de una medida que obliga a las empresas y entidades a documentar los flujos de datos que circulan en dichas organizaciones, recogiendo un contenido mínimo que podemos encontrar en el artículo 30 RGPD, como los fines del tratamiento, una descripción de las categorías de interesados y de datos personales y las transferencias a terceros países o los plazos previstos para su supresión, entre otros.

6 MEDIDAS DE CUMPLIMIENTO

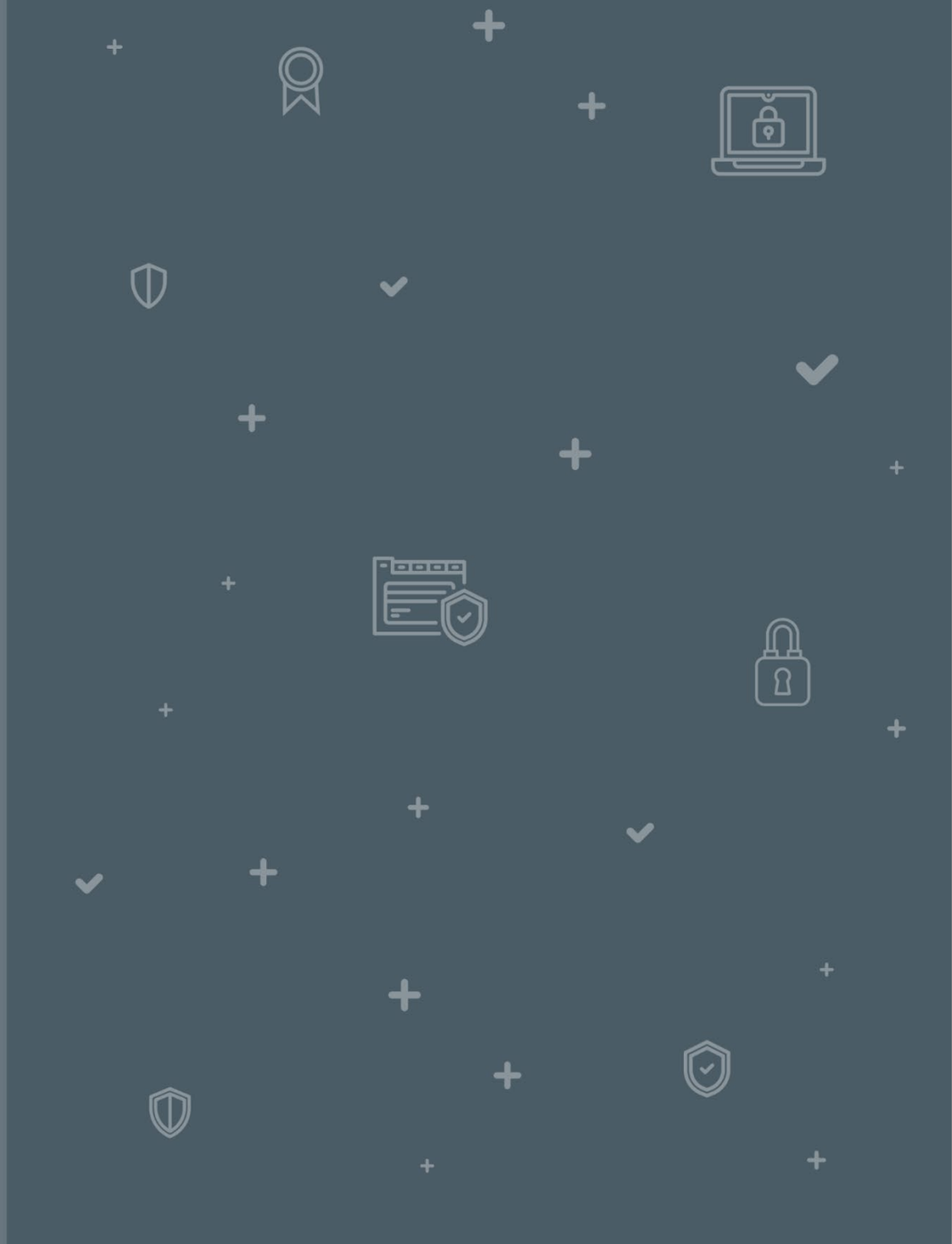
Registro de actividades del tratamiento

Solo las organizaciones que cumplan alguno de los siguientes requisitos deben llevar a cabo el registro:

- Organizaciones de más de 250 empleados.
- Organizaciones con menos de 250 empleados que realizan un tratamiento que:
  - Pueda conllevar un riesgo para los derechos y libertades de los interesados.
  - No sea ocasional.
  - Incluya categorías especiales de datos personales (origen étnico, afiliación social, etc.) o relativos a condenas e infracciones.

7

INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO



7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Introducción

Ahora que hemos comprendido las diferentes obligaciones del responsable del tratamiento de datos personales, ¿qué podría ocurrir si el responsable incumple con alguna de ellas? El RGPD también establece una serie de sanciones a las que el responsable del tratamiento está sujeto en caso de incumplimiento:

- El artículo 83.4 del RGPD establece una serie de incumplimientos en los que la multa puede llegar hasta 10 millones de euros o el 2% de la facturación del último ejercicio del responsable, en caso de que se trate de una empresa, y siempre se optará por la opción de mayor cuantía. No obstante, la multa puede ser de hasta 10 millones, siendo este el máximo importe. La cuantía se regulará en función de la naturaleza, gravedad, intencionalidad, categoría de datos afectada, etc., tal y como recoge el art. 83.2 RGPD. Por ejemplo, si el responsable incumple el artículo 25 del RGPD, que establece que se realizará una protección desde el diseño, y no realiza el análisis de los riesgos ni toma las medidas adecuadas para la protección de los datos, estará incurriendo en un incumplimiento de dicho artículo y la multa puede ascender hasta los 10 millones de euros.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Introducción

- En caso de que el incumplimiento sea más grave, el artículo 83.5 del RGPD establece que las sanciones pueden ascender hasta los 20 millones de euros o el 4% de la facturación del último ejercicio de la empresa, optándose también por la sanción de mayor cuantía, y al igual que en el caso anterior, la cifra puede alcanzar los 20 millones, pero la cuantía se regulará en función de la naturaleza, gravedad, intencionalidad, categoría de datos afectada, etc., tal y como se recoge en el art. 83.2 RGPD. Por ejemplo, si el responsable incumple alguno de los principios básicos para el tratamiento de datos como el principio de finalidad, la sanción podría ascender hasta 20 millones de euros.



7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Introducción

La cuantía de estas sanciones o multas económicas se establecerá en función de este artículo 83, atendiendo cada caso en particular y teniendo en cuenta diferentes aspectos como la naturaleza, gravedad, duración de la infracción, la intencionalidad de la misma, si el responsable o encargado del tratamiento tomaron medidas para mitigar el impacto negativo o las consecuencias de la infracción, etc.

¿Sabías qué?

Según el informe sobre el RGPD en la Unión Europea (2022), España es el quinto país con más sanciones por incumplimientos del RGPD. [19]



7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Medidas adicionales

Sin embargo, además de las posibles sanciones económicas, el RGPD otorga una serie de poderes en su artículo 58, donde se prevén otras medidas adicionales:

- **Advertencias**: se podrá sancionar al responsable o encargado del tratamiento con una advertencia cuando las operaciones previstas que realizan para el tratamiento puedan infringir el RGPD.
- **Amonestaciones**: se podrá amonestar al responsable o encargado del tratamiento cuando las operaciones del tratamiento de datos hayan infringido el RGPD.
- **Suspensiones del tratamiento de datos**: se podrá limitar de forma temporal o definitiva del tratamiento e incluso se puede llegar a prohibir el mismo.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Causas

Las causas más habituales de sanciones por incumplimiento del RGPD en España en suelen ser causas por:

- **Una base legal insuficiente para el tratamiento de datos**: por ejemplo, una empresa no es capaz de justificar debidamente la necesidad y legitimidad para realizar el tratamiento de los datos recogidos.
- **Las medidas técnicas y organizativas insuficientes** para garantizar la seguridad de los datos y evitar brechas de seguridad que pusieran en peligro los mismos: muchas de las brechas de seguridad que se han dado, se han debido a una mala planificación de la seguridad, permitiendo un acceso más fácil a la información por parte de terceros no autorizados.
- **El incumplimiento** de alguno de los principios generales en materia de tratamiento de datos.

¿Sabías qué?

Estas son las 10 multas más altas por incumplimiento del RGPD en España durante el primer trimestre de 2021. [20]

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador

El órgano encargado de la investigación de las infracciones e incumplimientos del RGPD en España es la AEPD (Agencia Española de Protección de Datos) y las normativas aplicables para ello son, tanto el RGPD como la LOPDGDD.

Como hemos visto, en los artículos 83 y 84 del RGPD se recogen las condiciones necesarias para la imposición de las sanciones o multas y también los aspectos que deben tenerse en cuenta a la hora de imponer la sanción. Sin embargo, al tratarse de un marco europeo, se atribuye a cada país miembro la autonomía para establecer las conductas y actuaciones que pueden ser objeto de sanción, así como los criterios que establecen el grado de infracción.

Por esta razón, en los artículos 63 al 78 de la LOPDGDD, se recogen tanto los procedimientos, en caso de posible vulneración de la normativa de protección de datos, como el régimen sancionador con el objetivo de completar aquellas lagunas del RGPD dado su carácter genérico en esta materia.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: causas

Lo primero que se debe tener en cuenta es que el procedimiento sancionador puede iniciarse por la concurrencia de una de estas dos causas, recogidas en el artículo 63:

- **La ausencia de atención de una solicitud del ejercicio de los derechos ARCO-POL**: que un interesado pretenda ejercer uno de sus derechos en materia de protección de datos y no haya recibido respuesta o considera que se continúa vulnerando alguno de sus derechos.
- **La AEPD esté investigando un posible incumplimiento o infracción del RGPD**.

En el artículo 66 se recoge la determinación del alcance territorial, esto es, establece la necesidad de examinar si la AEPD tiene competencia para tramitar el procedimiento. En caso contrario, la AEPD debe remitir la reclamación a la autoridad de control principal que considere competente e informar a la persona que interpuso la reclamación de ello.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: admisión de reclamaciones

El siguiente paso en la tramitación de este procedimiento es la admisión o inadmisión de la reclamación, recogida en el artículo 65. La AEPD realizará una evaluación de las reclamaciones o denuncias y en un plazo de 3 meses deberá admitir o inadmitir la reclamación, teniendo en cuenta que la falta de notificación en ese plazo conlleva la admisión de la reclamación. Por otro lado, se inadmitirán todas aquellas reclamaciones que cumplan alguna de las siguientes características:

- No guardan relación con la protección de datos de carácter personal.
- Carecen de fundamento.
- Son abusivas.
- No aportan indicios de que exista una infracción.
- El responsable o encargado del tratamiento ha adoptado las medidas necesarias para corregir el incumplimiento, mientras que no se haya perjudicado al afectado y los derechos del afectado estén garantizados a través de esas medidas.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: iniciación

Tras su admisión, se debe iniciar el procedimiento, recogido en el artículo 64, que establece diferentes formas de iniciación según la causa del procedimiento vistas en el artículo 63:

- Si el procedimiento se refería a la falta de atención de una solicitud para el ejercicio de algún derecho ARCO-POL, se iniciará el procedimiento por acuerdo de admisión a trámite, es decir, si la autoridad de control la admite, se iniciará el procedimiento y tendrá una duración máxima de 6 meses. Transcurrido dicho plazo, el interesado podrá dar la reclamación como estimada.
- Por el contrario, si el procedimiento hacía referencia a la investigación de un posible incumplimiento o infracción del RGPD, podrá iniciarse por iniciativa propia de la AEPD o a consecuencia de la reclamación de algún interesado. Tendrá una duración de 9 meses y, transcurrido dicho plazo, se entenderá el procedimiento caducado y se archivará. Además, en este caso, se podrá realizar de forma previa al inicio del procedimiento una fase de actuaciones de investigaciones, que se recoge en el artículo 67.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: investigación de los hechos

La AEPD podrá realizar actuaciones de investigación con el objetivo de determinar los hechos y circunstancias que justifiquen la tramitación del procedimiento sancionador. Algunas de las acciones que puede llevar a cabo son:

- Recabar la información necesaria para el cumplimiento de sus funciones.
- Realizar inspecciones.
- Solicitar la visualización de documentos o datos pertinentes.
- Examinar los equipos de información.
- Requerir la ejecución de tratamientos y programas sobre los que guarda relación la investigación con el fin de comprender su funcionamiento o proceso.



7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: investigación de los hechos

Una vez terminadas estas actuaciones de investigación previas, el artículo 68 establece el acuerdo de inicio del procedimiento para el ejercicio de la potestad sancionadora, donde se recogerán los hechos, la identificación de la persona física o jurídica contra la que se dirige el procedimiento, la posible infracción que se ha realizado y su correspondiente sanción.

Asimismo, en el artículo 69 se recogen diferentes medidas provisionales que pretenden salvaguardar el derecho a la protección de datos. Algunas de estas medidas son el bloqueo cautelar de los datos y la obligación de atender el derecho solicitado de forma inmediata.

¿Sabías qué?

Estas son las infracciones más comunes en materia de RGPD en Europa. [21]

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: tipos de sanciones

El artículo 70 establece las personas, físicas o jurídicas, que están sujetas al régimen sancionador. Los más destacados son los responsables y los encargados de los tratamientos de datos. Sin embargo, se debe mencionar que el DPO no puede ser objeto de sanción.

Las infracciones están recogidas en los artículo 71 al 74 de esta Ley. Se debe tener en cuenta que mientras que el RGPD solo establece dos rangos, como ya hemos visto; en la LOPDGDD se diferencian según puedan ser leves, graves o muy graves, y se determinan diferentes cuantías para las sanciones o multas dentro de las cuantías establecidas en el RGPD.



7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: tipos de sanciones

- **Sanciones por infracciones leves**: pueden alcanzar los 40.000 €. Algunos supuestos de infracciones leves son la falta de transparencia de la información, el incumplimiento de no informar al afectado cuando este lo haya solicitado, el incumplimiento de las obligaciones del encargado del tratamiento o la ausencia de atención a la solicitud de los derechos ARCO-POL por parte del titular de los datos. Estas sanciones prescriben en el plazo de un año, es decir, pasado un año ya no es posible proceder a la ejecución y cobro de la sanción impuesta.
- **Sanciones por infracciones graves**: el rango va de 40.001 € a 300.000 €. Algunos ejemplos de infracciones graves son la recogida de datos de menores sin el consentimiento, la ausencia de adopción de medidas técnicas y organizativas para lograr una adecuada y efectiva protección de los datos o el incumplimiento de designación de nombrar un responsable o encargado del tratamiento. El plazo de prescripción de estas sanciones es de dos años.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: tipos de sanciones

- **Sanciones por infracciones muy graves**: el rango establecido es de 300.001 € a 20.000.000 €, o el 4% de la facturación anual en caso de empresas y se seleccionará la cuantía de mayor valor. Algunos ejemplos de infracciones muy graves son el uso de los datos recabados para un fin distinto del tratamiento establecido, la obstrucción de una inspección por parte de la AEPD o la reversión deliberada de un proceso de anonimización permitiendo la reidentificación de los titulares de los datos. La prescripción de este tipo de sanciones es de tres años.



7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: tipos de sanciones

Además, para establecer las sanciones también se deberán tener en cuenta una serie de aspectos, que pueden suponer un factor agravante o atenuante, que se recogen en el artículo 76, siendo algunos de ellos:

- La continuidad de la infracción.
- Los beneficios obtenidos por parte del infractor por la comisión de la infracción.
- La posibilidad de que las acciones del afectado hayan podido incitar a la comisión de la infracción.
- Disponer, cuando no sea obligatorio, de un Delegado de Protección de Datos (DPO).
- Los derechos de los menores han sido afectados.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

Procedimiento sancionador: caso práctico

Veamos ahora cómo funciona el procedimiento sancionador con un ejemplo práctico.

Supongamos que Isabel López quiere ejercer el derecho de supresión para que eliminen sus datos de una página web de una empresa ABCD en la que aparece su foto sin su consentimiento. Isabel enviará una solicitud de supresión al responsable del tratamiento de ABCD para que eliminen la foto, pero no recibe respuesta alguna, así que decide poner una reclamación ante la AEPD.

Previamente, Isabel deberá recabar todas las pruebas sobre la infracción que pueda reunir, ya que cuanta más información pueda aportar, más probabilidades hay de que la reclamación prospere. Entonces, enviará toda la documentación con la reclamación donde la AEPD valorará si admitir la reclamación o no. Si trascurridos 3 meses, Isabel no ha recibido ninguna notificación, se entenderá que está admitida y se iniciará el procedimiento.

7 INFRACCIONES Y SANCIONES POR INCUMPLIMIENTO

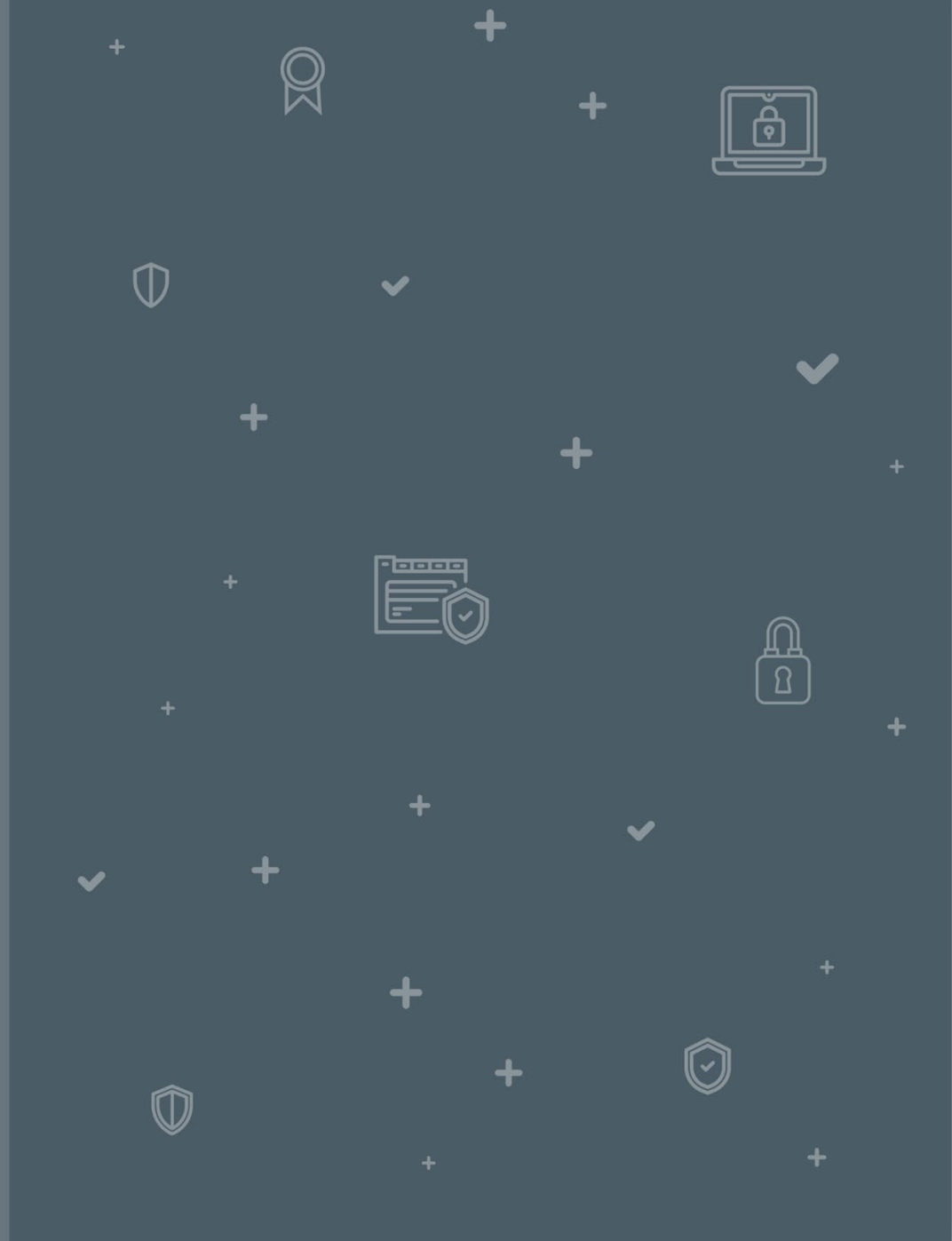
Procedimiento sancionador: caso práctico

Tras esto, la AEPD tiene un plazo de 6 meses para valorar la documentación y pruebas aportadas para resolver la reclamación de forma favorable o desfavorable. Al tratarse de una ausencia de atención de los derechos ARCO-POL y, por lo tanto, una infracción leve, la sanción a la empresa ABCD podría alcanzar los 40.000 €.

Realmente, el procedimiento sancionador pretende tener un carácter disuasorio y tanto los organismos públicos como las empresas deben cumplir con la normativa de protección de datos en todo momento. Por esta razón, las sanciones pueden alcanzar cifras tan elevadas.

8

GARANTÍAS DE LOS DERECHOS DIGITALES



8 GARANTÍAS DE LOS DERECHOS DIGITALES

Introducción

Las tecnologías digitales están cambiando la forma en la que se ejercen, protegen y vulneran los derechos de las personas como la libertad de expresión o el acceso a la información. Sin embargo, también ha provocado que nazcan o se reconozcan nuevos derechos. Por esta razón, la LOPDGDD contempla en su Título X la garantía de los derechos digitales.

Los derechos digitales o ciberderechos hacen referencia a aquellos derechos de las personas a acceder, usar, crear y publicar en medios digitales, así como el derecho de acceso a ordenadores, dispositivos electrónicos y redes de telecomunicaciones necesarios para ejercer estos derechos.

8 GARANTÍAS DE LOS DERECHOS DIGITALES

Características comunes

Los derechos digitales son una extensión de los derechos recogidos en la **Declaración Universal de los Derechos Humanos de la ONU** (Organización de las Naciones Unidas), con la característica principal de que son aplicados al mundo *online*.

Algunos de sus objetivos son garantizar el acceso a Internet, evitar o salvar la brecha digital o establecer un uso adecuado de la Red. Sin embargo, no se ha propiciado un consenso internacional, por lo que cada país ha desarrollado o está en proceso de desarrollar su propia Carta de Derechos Digitales.



8 GARANTÍAS DE LOS DERECHOS DIGITALES

Características comunes

Sin embargo, sí existen unas líneas generales que todos los países han seguido al definir su carta de Derechos Digitales:

- **Acceso universal e igualitario**: hace referencia a la posibilidad de que todas las personas puedan acceder a Internet, independientemente de sus ingresos, ubicación geográfica o discapacidad.
- **Libertad de expresión, información y comunicación**: estos derechos se ven vulnerados en Internet en el caso de que los gobiernos decidan bloquear sitios web o redes sociales.
- **Privacidad y protección de datos:** hace referencia a la necesidad de que las personas tengan control sobre sus datos y quién los almacena, así como la posibilidad de eliminarlos en cualquier momento.

8 GARANTÍAS DE LOS DERECHOS DIGITALES

Características comunes

- **Derecho al anonimato y al cifrado de comunicaciones:** que se ven vulnerados en países que prohíben el envío de mensajes y comunicaciones cifradas.
- **Derecho al olvido:** la información o datos personales de una persona se puede eliminar de los buscadores de Internet.
- **Protección del menor**: ofrecer medios que garanticen un acceso seguro sin infringir los derechos de los menores.
- **Propiedad intelectual**: se debe garantizar el reconocimiento de los autores y el derecho a ser remunerados, sin que esto interrumpa el libre acceso a las obras que sean de dominio público.

8 GARANTÍAS DE LOS DERECHOS DIGITALES

Carta de Derechos Digitales

¿Sabías qué?

En España, la Carta de Derechos Digitales fue adoptada el 14 de julio de 2021 por el Gobierno, en la que se recogen un total de 25 derechos. [22]

Sin embargo, esta Carta tiene por objeto ser un referente para una futura ley orgánica que regule los derechos digitales, pero no ser un proyecto de norma jurídica, lo que ha generado muchas críticas, ya que, realmente, no se recogen nuevos derechos, sino los derechos ya contemplados en otras normativas vigentes, como la LOPDGDD. Se trata de una guía de referencia u hoja de ruta que busca reforzar los derechos de los ciudadanos, aumentando la confianza de la sociedad en la era digital.

9

ESTÁNDAR NORMATIVO ISO 27701

9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

En la unidad anterior vimos que la ISO 27701 es la norma encargada de especificar los requisitos de privacidad para que las organizaciones generen evidencias de acuerdo al cumplimiento del RGPD. Se encarga de desarrollar un Sistema de Gestión de Información de Datos Personales (SGPD), que se desplegaba sobre un Sistema de Gestión de la Seguridad de Información (SGSI), propio de la ISO 27001. Aunque se trata de una norma que no es de obligado cumplimiento, favorece al cumplimiento de la legislación vigente ya que guarda ciertas similitudes con el RGPD, como veremos.



Además, este estándar establece una serie de requisitos o controles adicionales para los responsables y encargados del tratamiento de datos.

9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

Por otro lado, la responsabilidad proactiva en el ámbito de la privacidad es un principio articulado en el ordenamiento jurídico que engloba la adopción de una conducta diligente y consciente por parte de las organizaciones frente a todos los tratamientos de datos personales.

Se trata de una de las principales novedades que se introdujeron en el RGPD e implica el deber y la obligación de evitar y prevenir daños en relación con datos de carácter personal. Este pilar esencial pone el foco de atención desde un momento temprano, anticipándose a las amenazas debiendo, no solo de cumplir con la normativa, sino también en su demostración.

El principio de proactividad se extiende a lo largo de toda la vida de la organización o de sus proyectos pues, según el ciclo PDCA (que vimos en la unidad anterior), es continuo.

9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

Veamos un ejemplo práctico.

> Una empresa tecnológica de tamaño medio quiere comercializar una herramienta a través de la cual se prestará un servicio de atención al cliente para llevar una mejor gestión del servicio. Esta empresa, ubicada en Burgos y, por lo tanto, bajo el ordenamiento jurídico europeo, debe actuar de acuerdo al principio de proactividad.
>
> Consecuentemente, debe tener en cuenta desde fases iniciales (antes de su comercialización) la posible afectación de los datos personales que puedan tratarse a través de su herramienta. Para ello, se emplearán medidas, como la identificación de los riesgos al configurar la herramienta para usar los mínimos datos por defecto. Igualmente, se irán documentando las medidas correctoras que se han incorporado a la herramienta, pudiendo evidenciar que ha cumplido con las obligaciones y principios que exige el ordenamiento jurídico en privacidad.
>
> Además, la empresa irá pasando auditorias periódicas para su mejora continua y cumplimiento normativo.

9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

Si tenemos en cuenta los requisitos específicos que establece la ISO 27701, podemos añadir que el estándar internacional obliga a examinar el contexto de la organización, tanto el interno como el externo. Así, se atenderá a los factores particulares de la organización, como los roles, la actividad sectorial, el nivel de tecnología, la legislación o la regulación aplicable y jurisprudencia, entre otros.

Esta apreciación del contexto, junto al principio de responsabilidad proactiva, determina las medidas técnicas y organizativas que se incluirán en la organización.

De esta manera, y con la finalidad de evidenciar el cumplimiento en privacidad, la ISO 27701 obliga a procedimentar y establecer (tomando en consideración las particularidades de la organización) una serie de mecanismos para recoger estas medidas técnicas y organizativas comenzando con documentación de la política de seguridad y privacidad.

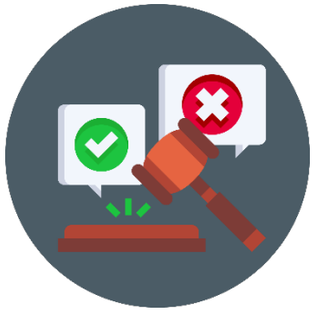
9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

En la política de seguridad y privacidad se provee orientación y apoyo, conteniendo así las directrices generales que marquen las pautas en privacidad, junto a las de seguridad al estar implementada la ISO 27701 sobre la ISO 27001 de acuerdo con los requisitos del negocio y con las regulaciones y leyes pertinentes.

En ella, se establecen, entre otras disposiciones, la identidad del responsable del tratamiento de datos y el delegado de protección de datos (si lo hubiese), procedimientos de incidencias de privacidad, procedimientos de ejercicio de derechos, etc. Estas exigencias incluyen, como mínimo, todas aquellas recogidas en el RGPD.

Por último, junto a la definición de un proceso continuo de mejora, la ISO 27701 incluye como requisito adicional la realización de auditorias periódicas. Como veíamos en el ejemplo anterior, las auditorías pondrán de manifiesto aquellos puntos en los que una organización debe corregir o simplemente evidenciar el cumplimiento normativo.



9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

Tanto la ISO 27701 como el RGPD presentan una serie de similitudes, ya que ambas normativas pretender proteger a los consumidores a través de unas normas éticas de privacidad de datos. Algunas de ellas son:

- **Realizar una evaluación de riesgos**: ambas establecen que las organizaciones deben evaluar los riesgos a los que son susceptibles los datos, antes de realizar cualquier tratamiento sobre ellos.
- **Ser responsable frente a las violaciones de datos**: las organizaciones deben informar de cualquier violación de seguridad a las autoridades.
- **Asesorar sobre la protección de datos en cada etapa**: se exige mantener la confidencialidad de los datos en todas las fases de su ciclo de vida y solo se deben utilizar aquellos datos que sean necesarios.
- **Mantener registros**: se debe llegar un registro de las actividades de tratamiento y procesos de seguridad, ya que pueden ayudar a las autoridades, en caso de que se produzca una violación de datos.

9 ESTÁNDAR NORMATIVO ISO 27701

ISO 27701 – Gestión de la Privacidad

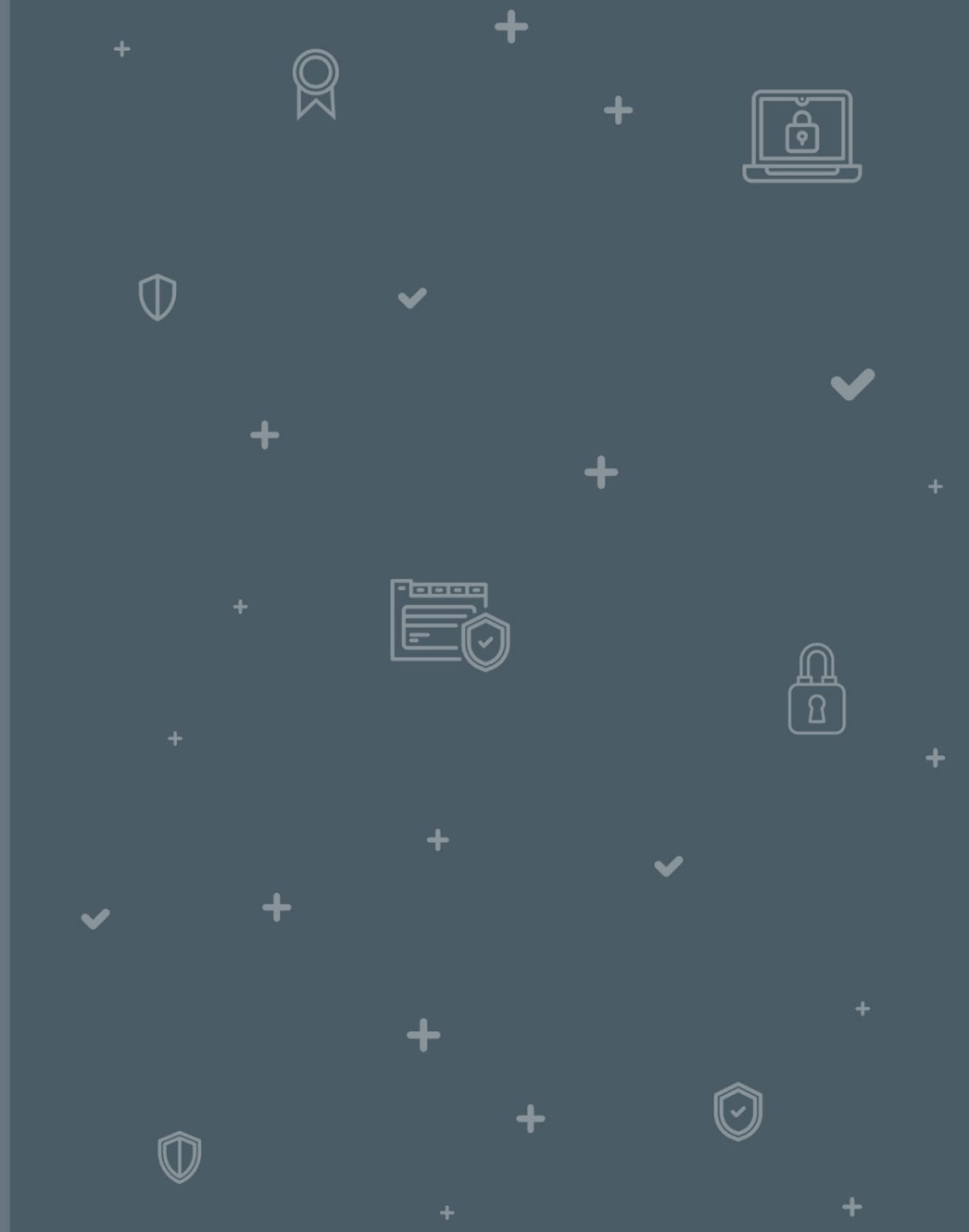
Sin embargo, también existen diferencias entre ambas normas:

- **Aplicación**: mientras el RGPD se centra en la protección de datos personales, su confidencialidad y la gestión de riesgos para los derechos de las personas, la ISO 27701 dispone unas directrices de mejora de las medidas de seguridad de los datos, las políticas que pueden aplicar y cómo pueden reducir los riesgos.
- **Medidas de protección**: el RGPD no ofrece ningún detalle técnico sobre cómo mantener un adecuado nivel de seguridad de los datos, mientras que la ISO 27701 proporciona una serie de medidas que las organizaciones pueden llevar a cabo para reducir las amenazas.

Es importante tener en cuenta que cumplir la ISO 27701 no significa cumplir el RGPD, pese a que compartan ciertos aspectos. Además, cumplir con el RGPD es obligatorio, mientras la ISO 27701 no lo es.



RESUMEN, CONCLUSIONES Y REFERENCIAS



RESUMEN

- La **protección de datos** provocó la necesidad de crear el **Reglamento General de Protección de Datos (RGPD)** de la Unión Europea en 2016 con el objetivo de reforzar y unificar la protección de los datos de los individuos europeos, así como la libre circulación de datos personales en el territorio de la Unión Europea. Además, en España, también destaca la **Ley Orgánica de Protección de Datos y Garantías de los Derechos Digitales (LOPDGDD)** que entró en vigor en 2018 con el fin de adaptar el Derecho español al RGPD y completar algunos vacíos legales que el RGPD pone a disposición de la decisión autónoma de los Estados miembros.

- Los **datos personales** conforman el núcleo sobre el que se desarrolla el Reglamento General de Protección de Datos (RGPD). Sobre ellos, podemos realizar una serie de operaciones que el legislador denomina «tratamiento de datos». La finalidad del tratamiento de datos personales que hace referencia a los motivos, usos y objetivos que el responsable del tratamiento de los datos aplicará legalmente sobre los datos recabados.

RESUMEN

- Durante el **procesamiento de los datos** se llevan a cabo una serie de fases desde el momento de la recogida de los mismos hasta su eliminación. Este proceso se conoce como ciclo de vida de los datos y, por lo general, existen cinco etapas o categorías: la recogida o generación de los datos, el registro o almacenamiento, el uso y tratamiento de datos, la comunicación o cesión de los mismos y su finalización o destrucción.
- Los **principios** que recoge el RGPD para el tratamiento de datos son: el principio de licitud, transparencia y lealtad, el principio de finalidad, el principio de minimización de datos, el principio de exactitud, el principio de limitación del plazo de conservación, el principio de seguridad y el principio de responsabilidad activa.

RESUMEN

- Los **derechos ARCO-POL o ARSULIPO** son: derecho de **Acceso** o derecho a saber si los datos están siendo tratados; derecho de **Rectificación**, que permite al interesado solicitar la modificación de los datos que no sean exactos o estén incompletos; derecho de **Supresión** o derecho a obtener la supresión de los datos personales que le conciernan; derecho al **Olvido**, es decir, la extensión del derecho de supresión en el marco de los motores de búsqueda de Internet; derecho a la **Limitación del tratamiento** o derecho a exigir al responsable del tratamiento la limitación del mismo respecto a sus datos; derecho de **Portabilidad** o derecho a solicitar el traslado de los datos a otro responsable; y derecho de **Oposición** o derecho a oponerse al tratamiento de los datos.

RESUMEN

- El órgano encargado de la investigación de las infracciones e incumplimientos del RGPD en España es la **Agencia Española de Protección de Datos** (AEPD) y las normativas aplicables para ello son tanto el RGPD como la LOPDGDD.
- Los **derechos digitales** son una extensión de los derechos recogidos en la Declaración Universal de los Derechos Humanos de la ONU y tienen características comunes a nivel internacional: acceso universal e igualitario, libertad de expresión, información y comunicación; privacidad y protección de datos, derecho al anonimato y al cifrado de comunicaciones, derecho al olvido, protección del menor y garantía de propiedad intelectual.

CONCLUSIONES

- Los **derechos fundamentales** son derechos que tienen el máximo nivel de protección y son inalienables, inviolables e irrenunciables. En este sentido, el **derecho de protección de datos** es un derecho fundamental que permite a las personas tener el control sobre el uso que se hace con sus datos personales.
- En España, la protección de datos se regula tanto en el Reglamento General de Protección de Datos (**RGPD**) como en la Ley Orgánica de Protección de Datos y Garantías de los Derechos Digitales (**LOPDGDD**). Cuando hablamos de protección de datos, debemos diferenciar dos conceptos: la **seguridad de los datos**, que hace referencia a las medidas de protección de los mismos; y la **privacidad de los datos**, basada en asegurar que los datos se traten de acuerdo a la normativa vigente.

CONCLUSIONES

- Los **datos personales** son toda aquella información que nos permita, de forma directa o indirecta, identificar a una persona concreta. Existen diferentes **tipos de datos personales**: datos de carácter personal, que pueden ser ordinarios o sensibles; categorías especiales de datos, que requieren mayor precaución, su recopilación y uso puede interferir con los derechos fundamentales o conducir a la discriminación; y datos de naturaleza penal, es decir, datos personales sobre las denuncias, los procedimientos o las condenas penales.
- El Reglamento General de Protección de Datos (RGPD) incorpora una serie de **novedades** como la necesidad de consentimiento expreso, la obligación de nombrar un Delegado de Protección de Datos en determinados supuestos, la modificación en la aplicación de las medidas de seguridad en función del riesgo que conlleve el tratamiento concreto; los derechos ARCO-POL y las sanciones por el incumplimiento de la normativa.
- Los derechos **ARCO-POL, o también llamados ARSULIPO** son los derechos de los que disponen los interesados respecto del tratamiento de sus datos personales. Entre sus características destacan que son personalísimos e independientes.

CONCLUSIONES

- El **responsable del tratamiento** es aquella persona física o jurídica o autoridad pública que determina los fines y los medios para el tratamiento de datos, establece las medidas técnicas y organizativas que garanticen la seguridad de los mismos y debe demostrar el cumplimiento del RGPD.
- El **encargado del tratamiento** es aquella persona que ejecuta, que realiza el tratamiento de datos por cuenta del responsable, siguiendo las directrices que éste le indica. Las obligaciones del encargado del tratamiento son organizativas y de seguridad.
- Las **medidas de cumplimiento** que se consideran obligaciones del responsable del tratamiento son, entre otras, realizar un análisis de riesgos, llevar un registro de actividades de los tratamientos, respetar el principio de protección de datos desde el diseño y el principio de protección de datos por defecto, llevar a cabo las medidas de seguridad necesarias para proteger los datos, notificar las brechas de seguridad que ocurran, realizar una evaluación de impacto de la protección de datos y designar un Delegado de Protección de Datos, cuando así lo disponga la norma.

CONCLUSIONES

- El **DPO (Delegado de Protección de Datos)** es la persona encargada de informar a la entidad responsable o al encargado del tratamiento sobre sus obligaciones legales respecto a la protección de datos.
- El RGPD establece dos grupos de **sanciones por infracciones:** hasta los 10 millones de euros o el 2% de la facturación del último ejercicio; o por infracciones graves, hasta los 20 millones de euros o el 4% de la facturación del último ejercicio. Además, el RGPD prevé **otras medidas adicionales** como advertencias, amonestaciones y suspensiones del tratamiento de datos.
- El **procedimiento sancionar** recogido en el RGPD y en la LOPDGDD para completar las lagunas que deja el RGPD establecen dos **causas** por las que se puede iniciar un procedimiento: ausencia de atención de una solicitud del ejercicio de los derechos ARCO-POL e investigación un posible incumplimiento o infracción del RGPD.
- Los **derechos digitales** permiten a las personas acceder, usar, crear y publicar medios digitales, así como el derecho de acceso a ordenadores, dispositivos electrónicos y redes de telecomunicaciones necesarios para su ejercicio. En España, existe la Carta de Derechos Digitales.

REFERENCIAS

- Diferencias entre seguridad y privacidad de los datos.
  https://www.redeszone.net/tutoriales/seguridad/seguridad-vs-privacidad-diferencias/

- Tipos de datos personales.
  https://protecciondatos-lopd.com/empresas/datos-personales/#Tipos_de_datos_personales

- Gestión del riesgo y evaluación de impacto en tratamientos de datos personales.
  https://www2.deloitte.com/es/es/pages/technology/articles/IoT-internet-of-things.html

- Principios de la RGDP.
  https://www.aepd.es/es/derechos-y-deberes/cumple-tus-deberes/principios

REFERENCIAS COMPLEMENTARIAS

[1] Artículo 18 de la Constitución Española, en la Carta de los Derechos Fundamentales de la Unión Europea y en el Tratado de Funcionamiento de la Unión Europea.
https://www.boe.es/buscar/act.php?id=BOE-A-1978-31229#a18

[2] A principios de 2014, unos ciberdelincuentes robaron más de 3.000 millones de datos de usuarios.
https://www.xataka.com/seguridad/el-hackeo-a-yahoo-fue-mas-grave-de-lo-que-pensabamos-3-000-millones-de-cuentas-robadas-todas-las-que-tenia-en-2013

[3] Guía de la Agencia Española de Protección de Datos.
https://www.aepd.es/es/documento/gestion-riesgo-y-evaluacion-impacto-en-tratamientos-datos-personales.pdf

[4] La AEPD sancionó con un millón de euros a una organización por recopilar datos incumpliendo la normativa.
https://alcatraz.es/2021/04/30/la-aepd-multa-con-un-millon-de-euros-a-equifax-por-gestionar-un-fichero-de-morosos-ilegal/

REFERENCIAS COMPLEMENTARIAS

[5] La AEPD multó a una empresa bancaria por cobrar comisiones a cambio de no ceder datos personales. https://www.abogacia.es/actualidad/noticias/multan-a-caixabank-por-cobrar-comisiones-a-cambio-de-no-ceder-datos-personales/

[6] Sobre todas las funciones y poderes propios de la AEPD. https://www.aepd.es/es/la-agencia/transparencia/informacion-de-caracter-institucional-organizativa-y-de-planificacion/funcion-y-poderes

[7] La Agencia Española de Protección de Datos (AEPD). https://www.aepd.es/es/la-agencia/transparencia/informacion-de-caracter-institucional-organizativa-y-de-planificacion/funcion-y-poderes

[8] Una empresa bancaria fue multada con 200.000 euros por no aplicar las medidas técnicas y organizativas. https://confilegal.com/20210828-la-aepd-impone-una-multa-de-200-000-euros-a-bbva-por-no-garantizar-la-seguridad-en-el-tratamiento-de-datos/

REFERENCIAS COMPLEMENTARIAS

[9] Empresas como Meta, propietaria de Facebook e Instagram, amenazaron con retirar sus servicios de la UE si no se facilita la trasferencia de datos con EE.UU.
https://www.xataka.com/legislacion-y-derechos/meta-amenaza-retirar-facebook-e-instagram-ue-no-se-facilita-transferencia-datos-estados-unidos

[10] La AEPD sancionó a un detective privado con 2.000 euros por no facilitar información al interesado sobre el tratamiento de sus datos.
https://www.aepd.es/es/documento/ps-00221-2021.pdf

[11] Existen sanciones de 100.00 euros por recuperar datos bloqueados de forma indebida.
https://observatorionormativo.ecixgroup.com/la-aepd-impone-una-sancion-a-kutxabank-de-100_000-por-intentar-recuperar-datos-bloqueados_/

[12] Art. 46 del RGPD.
https://www.privacy-regulation.eu/es/46.htm

REFERENCIAS COMPLEMENTARIAS

[13] La AEPD sancionó a una compañía aérea con 30.000 euros por no permitir a los usuarios oponerse al uso de *cookies.*
https://observatorionormativo.ecixgroup.com/la-aepd-impone-una-sancion-a-kutxabank-de-100_000-por-intentar-recuperar-datos-bloqueados_/

[14] La AEPD impuso una multa de 25.000 euros a una organización por no disponer de la figura DPO.
https://trebiaabogados.com/la-apd-multa-con-25-000-euros-a-glovo-por-no-tener-designado-un-delegado-de-proteccion-de-datos-dpo/

[15] La autoridad de control (AEPD) quien establecerá y publicará una lista de los tipos de operaciones de tratamiento que necesitan una evaluación de impacto.
https://www.aepd.es/sites/default/files/2019-09/listas-dpia-es-35-4.pdf

[16] La AEPD impuso una multa de 9,94 millones de euros por insuficiencia en las medidas de seguridad de una organización a la hora de expedir duplicados de la tarjeta SIM de dispositivos móviles.
https://rgpdblog.com/la-aepd-impone-a-vodafone-una-multa-de-394-millones-de-euros-por-faltas-de-medidas-de-seguridad-adecuadas-en-su-proceso-para-expedir-duplicados-de-la-tarjeta-sim/

REFERENCIAS COMPLEMENTARIAS

[17] *Risk Based Security* (2020): se notificaron alrededor de 4.000 brechas de seguridad, en las que se fugaron 37 billones de registros de datos.
https://www.riskbasedsecurity.com/2021/01/21/new-research-no-of-records-exposed-increased-141-in-2020/

[18] La AEPD dispone de una herramienta y un formulario online para notificar brechas de seguridad.
https://www.incibe.es/protege-tu-empresa/blog/comunica-brecha-rgpd-herramienta-te-asesora-brecha-seguridad

[19] Según el informe sobre el RGPD en la Unión Europea (2022), España es el quinto país con más sanciones por incumplimientos del RGPD.
https://www.lawyerpress.com/wordpress/wp-content/uploads/2022/01/Data-Breach-Report-2022_DLAPIPER.pdf

[20] Estas son las 10 multas más altas por incumplimiento del RGPD en España durante el primer trimestre de 2021.
https://rgpdblog.com/ranking-de-las-10-multas-mas-altas-en-espana-por-infraccion-del-rgpd-1er-trimestre-2021/

[21] Estas son las infracciones más comunes en materia de RGPD en Europa.
https://www.enforcementtracker.com/

¡GRACIAS!

GOBIERNO DE ESPAÑA

VICEPRESIDENCIA PRIMERA DEL GOBIERNO

MINISTERIO DE ASUNTOS ECONÓMICOS Y TRANSFORMACIÓN DIGITAL

SECRETARÍA DE ESTADO DE DIGITALIZACIÓN E INTELIGENCIA ARTIFICIAL

incibe_

INSTITUTO NACIONAL DE CIBERSEGURIDAD

017